UNIVERSIDADE PAULISTA – UNIP

BACHARELADO EM CIÊNCIA DA COMPUTAÇÃO

CAIO SCORSONI MARTINS OLIVEIRA

CAIO VINICIUS LUIZ ALVES

GUILHERME DOS SANTOS SALUSTIANO

GUSTAVO HENRIQUE RODRIGUES DE MAGALHÃES

ROBERT ESTEVAN DA SILVA JUNIOR

SISTEMA *WEB* PARA ATELIÊ E ESTÚDIO DE TATUAGEM

CAMPINAS – SP

2026

CAIO SCORSONI MARTINS OLIVEIRA

CAIO VINICIUS LUIZ ALVES

GUILHERME DOS SANTOS SALUSTIANO

GUSTAVO HENRIQUE RODRIGUES DE MAGALHÃES

ROBERT ESTEVAN DA SILVA JUNIOR

SISTEMA *WEB* PARA ATELIÊ E ESTÚDIO DE TATUAGEM

Trabalho de Conclusão de Curso apresentado à Universidade Paulista como requisito para a obtenção do título de Bacharel em Ciência da Computação.

Orientadora: Prof.ª Dr.ª Elisa Botta

CAMPINAS – SP

2026

DEDICATÓRIA

Dedicamos este trabalho aos nossos familiares, que nos apoiaram incondicionalmente ao longo de toda a nossa jornada universitária, aos nossos professores e mestres, que compartilharam seu conhecimento e exigiram nosso melhor, e aos colegas do curso de Ciência da Computação, cuja convivência e cooperação tornaram este percurso enriquecedor.

AGRADECIMENTOS

Agradecemos a Deus, pela força, saúde e resiliência concedidas em todos os momentos desafiadores desta trajetória acadêmica.

Aos nossos pais e familiares, pelo suporte incansável, incentivo constante e por fornecerem as condições essenciais para a concretização deste sonho.

À Prof.ª Dr.ª Elisa Botta, pela orientação atenta, rigor acadêmico e pelas valiosas diretrizes metodológicas que orientaram este trabalho desde o projeto no TCC 1 até a conclusão na presente monografia.

À administradora e tatuadora Melanie Schwark e aos artistas residentes do Kolô Ateliê & Estúdio, pela disponibilidade nas etapas de diagnóstico e de validação, e por colaborarem com a equipe ao longo da realização desta pesquisa-ação.

Aos colegas de curso e a todos que, direta ou indiretamente, contribuíram para a materialização deste sistema.

RESUMO

Este Trabalho de Conclusão de Curso (TCC) aborda a modernização dos processos operacionais do Kolô Ateliê & Estúdio, empreendimento de Pinheiros, São Paulo, que comercializa obras físicas de arte autoral e presta serviços personalizados de tatuagem. O diagnóstico revelou controle manual do acervo por mensagens descentralizadas e sobrecarga na triagem inicial das sessões de tatuagem. Diante disso, o trabalho projeta, desenvolve e avalia uma plataforma *web* integrada sob arquitetura de monólito modular, com Next.js 16, TypeScript, Tailwind CSS e PostgreSQL 17. A hipótese investigada estabelece que a centralização do catálogo, com pagamento sob reserva temporária de estoque, e um assistente determinístico em etapas direcionado ao WhatsApp eliminam controles manuais, previnem vendas duplicadas de peças exclusivas e qualificam o atendimento inicial. O sistema emprega bloqueio pessimista ordenado (SELECT ... FOR UPDATE) para reserva atômica de dez minutos, processamento idempotente de *webhooks* autenticados via HMAC-SHA256 (Mercado Pago), *uploads* com URLs pré-assinadas (Cloudflare R2) e anonimização cadastral em conformidade com a LGPD, sem armazenar dados sensíveis de saúde. A validação técnica reuniu 562 testes unitários, 276 de integração com PostgreSQL real e 43 ponta a ponta (Playwright); experimentos de concorrência sem *overselling*; auditoria Lighthouse com LCP de 2,43 s no catálogo e 2,25 s na ficha da obra; e avaliação automatizada WCAG 2.1 A/AA via axe-core, sem violações críticas ou sérias, restando pendente a verificação de teclado e foco. A validação assistida com a administradora e tatuadora do ateliê registrou avaliação positiva da identidade visual e da navegação. A implantação em produção foi projetada e permanece como etapa subsequente. Os resultados sustentam parcialmente a hipótese formulada.

Palavras-chave: Engenharia de Software; Comércio Eletrônico; Controle de Concorrência; Monólito Modular; LGPD.

ABSTRACT

This Final Course Project (TCC) addresses the modernization of operational processes at Kolô Ateliê & Estúdio, an enterprise in Pinheiros, São Paulo, which sells physical authorial artworks and provides personalized tattoo services. Process diagnosis revealed manual inventory control through decentralized messaging and overload in the initial screening of tattoo sessions. Given this scenario, this work designs, develops, and evaluates an integrated web platform following a modular monolith architecture, with Next.js 16, TypeScript, Tailwind CSS, and PostgreSQL 17. The investigated hypothesis states that catalog centralization, with payment under temporary inventory reservation, and a deterministic multi-step assistant routed to WhatsApp eliminate manual controls, prevent duplicate sales of single-edition pieces, and qualify initial service. The system employs ordered pessimistic locking (SELECT ... FOR UPDATE) for atomic ten-minute reservations, idempotent processing of webhooks authenticated via HMAC-SHA256 (Mercado Pago), pre-signed URL uploads (Cloudflare R2), and user anonymization in compliance with the LGPD, without storing sensitive health data. Technical validation comprised 562 unit tests, 276 integration tests with real PostgreSQL, and 43 end-to-end tests (Playwright); concurrency experiments with no overselling; a Lighthouse audit with 2.43 s LCP on the catalog and 2.25 s on the artwork page; and automated WCAG 2.1 A/AA assessment using axe-core, with no critical or serious violations, while keyboard and focus verification remains pending. The assisted validation session with the studio's administrator and tattoo artist recorded positive feedback on visual identity and navigation. Production deployment was designed and remains a subsequent stage. The results partially sustain the formulated hypothesis.

Keywords: Software Engineering; E-commerce; Concurrency Control; Modular Monolith; LGPD.

LISTA DE FIGURAS

Figura 4.1 — Diagrama de Arquitetura da Aplicação Kolô 52

Figura 4.2 — Modelo Entidade-Relacionamento do Banco de Dados Relacional (DER) 56

Figura 4.3 — Diagrama de Casos de Uso do Sistema Kolô 58

Figura 4.4 — Diagrama de Classes do Domínio 59

Figura 4.5 — Diagrama de Sequência da Reserva Temporária de Estoque (RF15) 61

Figura 4.6 — Diagrama de Sequência do Processamento do *Webhook* de Pagamento (RF14) 63

Figura 4.7 — Catálogo de Obras de Arte (RF09) 67

Figura 4.8 — Ficha Detalhada de uma Obra Disponível (RF10) 68

Figura 4.9 — Pedido com Reserva Ativa e Ação de Pagamento (RF12, RF13, RF15) 69

Figura 4.10 — Avisos Obrigatórios do Assistente de Agendamento (RF20, RF23, RF24, RF25) 70

Figura 4.11 — Galeria de Tatuagens com Filtros (RF17, RF18) 71

Figura 4.12 — Detalhe Administrativo de um Pedido para Entrega (RF29) 72

Figura 4.13 — Relatório Administrativo de Vendas por Período (RF32) 73

LISTA DE QUADROS

Quadro 2.1 — Análise Comparativa entre Soluções de Mercado e a Plataforma Kolô 24

Quadro 3.1 — Matriz Justificada de Mudança de Escopo entre TCC 1 e TCC 2 41

Quadro 4.1 — Requisitos Funcionais do Sistema Kolô (RF01 a RF32) 45

Quadro 4.2 — Requisitos Não Funcionais do Sistema Kolô (RNF01 a RNF24) 47

Quadro 4.3 — Estrutura de Módulos de Domínio da Aplicação (src/modules/)..... 54

Quadro 5.1 — Matriz de Rastreabilidade e Cobertura de Requisitos Funcionais..... 75

LISTA DE TABELAS

Tabela 5.1 — Resultados do Experimento de Concorrência de Reserva de Estoque 77

Tabela 5.2 — Métricas de Desempenho e Qualidade *Web* (Lighthouse 12.8.2, Mediana de 3 Rodadas) 79

LISTA DE ABREVIATURAS E SIGLAS

3FN	Terceira Forma Normal
ACID	Atomicidade, Consistência, Isolamento e Durabilidade (*Atomicity, Consistency, Isolation, Durability*)
ANSI	Instituto Nacional Americano de Padrões (*American National Standards Institute*)
API	Interface de Programação de Aplicações (*Application Programming Interface*)
ARIA	Aplicações Ricas de Internet Acessíveis (*Accessible Rich Internet Applications*)
AWS	Serviços *Web* da Amazon (*Amazon Web Services*)
CalDAV	Extensões de Calendário para WebDAV (*Calendaring Extensions to WebDAV*)
CEP	Código de Endereçamento Postal
CGI.br	Comitê Gestor da Internet no Brasil
CI	Integração Contínua (*Continuous Integration*)
CLS	Deslocamento Cumulativo de *Layout* (*Cumulative Layout Shift*)
CORS	Compartilhamento de Recursos entre Origens (*Cross-Origin Resource Sharing*)
CRUD	Criar, Ler, Atualizar e Excluir (*Create, Read, Update, Delete*)
CSP	Política de Segurança de Conteúdo (*Content Security Policy*)
CSRF	Falsificação de Requisição entre Sites (*Cross-Site Request Forgery*)
CSS	Folhas de Estilo em Cascata (*Cascading Style Sheets*)
CSV	Valores Separados por Vírgula (*Comma-Separated Values*)
DDL	Linguagem de Definição de Dados (*Data Definition Language*)
DER	Diagrama Entidade-Relacionamento

E2E	Ponta a Ponta (*End-to-End*)
FCP	Primeira Pintura de Conteúdo (*First Contentful Paint*)
GiST	Árvore de Busca Generalizada (*Generalized Search Tree*)
HMAC	Código de Autenticação de Mensagem Baseado em *Hash* (*Hash-based Message Authentication Code*)
HSTS	Segurança Estrita de Transporte HTTP (*HTTP Strict Transport Security*)
HTML	Linguagem de Marcação de Hipertexto (*HyperText Markup Language*)
HTTP	Protocolo de Transferência de Hipertexto (*Hypertext Transfer Protocol*)
HTTPS	Protocolo de Transferência de Hipertexto Seguro (*Hypertext Transfer Protocol Secure*)
IA	Inteligência Artificial
ID	Identificador
IDE	Ambiente de Desenvolvimento Integrado (*Integrated Development Environment*)
JSONB	JSON em formato binário (*JavaScript Object Notation Binary*)
JSX	Extensão de sintaxe XML para JavaScript (*JavaScript XML*)
LCP	Maior Pintura de Conteúdo (*Largest Contentful Paint*)
LGPD	Lei Geral de Proteção de Dados Pessoais (Lei Federal nº 13.709/2018)
LTS	Suporte de Longo Prazo (*Long-Term Support*)
MER	Modelo Entidade-Relacionamento
MIME	Extensões Multipropósito de Correio da Internet (*Multipurpose Internet Mail Extensions*)
OAuth	Protocolo Aberto de Autorização (*Open Authorization*)
ORM	Mapeamento Objeto-Relacional (*Object-Relational Mapping*)

OWASP	Projeto Aberto de Segurança em Aplicações *Web* (*Open Worldwide Application Security Project*)
PBI	Item do *Backlog* do Produto (*Product Backlog Item*)
PCI DSS	Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (*Payment Card Industry Data Security Standard*)
PHP	Pré-processador de Hipertexto (*PHP: Hypertext Preprocessor*)
PR	Solicitação de Integração (*Pull Request*)
RBAC	Controle de Acesso Baseado em Papéis (*Role-Based Access Control*)
REST	Transferência de Estado Representacional (*Representational State Transfer*)
RF	Requisito Funcional
RFC	Pedido de Comentários (*Request for Comments*)
RN	Regra de Negócio
RNF	Requisito Não Funcional
RSC	Componentes de Servidor React (*React Server Components*)
S3	Serviço de Armazenamento Simples (*Simple Storage Service*)
SAQ-A	Questionário de Autoavaliação, tipo A, do PCI DSS (*Self-Assessment Questionnaire A*)
SDK	Kit de Desenvolvimento de Software (*Software Development Kit*)
SEO	Otimização para Motores de Busca (*Search Engine Optimization*)
SHA	Algoritmo de *Hash* Seguro (*Secure Hash Algorithm*)
SQL	Linguagem de Consulta Estruturada (*Structured Query Language*)
SQLi	Injeção de SQL (*SQL Injection*)
TBT	Tempo Total de Bloqueio (*Total Blocking Time*)
TCC	Trabalho de Conclusão de Curso
TDD	Desenvolvimento Orientado a Testes (*Test-Driven Development*)

TI	Tecnologia da Informação
TIC	Tecnologias da Informação e Comunicação
TLS	Segurança da Camada de Transporte (*Transport Layer Security*)
TSX	Extensão de sintaxe XML para TypeScript (*TypeScript XML*)
UF	Unidade da Federação
UML	Linguagem de Modelagem Unificada (*Unified Modeling Language*)
UNIP	Universidade Paulista
URI	Identificador Uniforme de Recurso (*Uniform Resource Identifier*)
URL	Localizador Uniforme de Recurso (*Uniform Resource Locator*)
UTC	Tempo Universal Coordenado (*Coordinated Universal Time*)
UUID	Identificador Único Universal (*Universally Unique Identifier*)
VPS	Servidor Virtual Privado (*Virtual Private Server*)
W3C	Consórcio da Rede Mundial de Computadores (*World Wide Web Consortium*)
WCAG	Diretrizes de Acessibilidade para Conteúdo *Web* (*Web Content Accessibility Guidelines*)
WebGL	Biblioteca Gráfica para a *Web* (*Web Graphics Library*)
XSS	Scripting entre Sites (*Cross-Site Scripting*)

SUMÁRIO

1 INTRODUÇÃO 16
1.1 Contextualização 16
1.2 Problema de Pesquisa 17
1.3 Hipótese de Pesquisa 18
1.4 Objetivo Geral 18
1.5 Objetivos Específicos 19
1.6 Justificativa 20
1.7 Estrutura do Trabalho 21
2 FUNDAMENTAÇÃO TEÓRICA 22
2.1 Sistemas *Web* e Comércio Eletrônico na Economia Criativa 22
2.2 Trabalhos Relacionados e Comparação entre Soluções de Mercado 23
2.3 Controle de Concorrência e Integridade Transacional 25
2.4 Segurança da Informação em Aplicações *Web* (OWASP Top 10) 27
2.4.1 Injeção de Código e Injeção de SQL (A03:2021 — *Injection*) 27
2.4.2 *Cross-Site Scripting* (A03:2021 — XSS) e Proteção de Borda 27
2.4.3 Autenticação Segura com *Hash* scrypt (A07:2021 — *Identification and Authentication Failures*) 28
2.4.4 Autenticidade e Idempotência de *Webhooks* Criptográficos (HMAC-SHA256) 29
2.5 Privacidade e Conformidade com a LGPD (Lei nº 13.709/2018) 29
2.5.1 Princípios de Minimização e Finalidade (Artigo 6º) 30
2.5.2 Tratamento de Dados Sensíveis de Saúde na Tatuagem (Artigo 11) 30
2.5.3 Direito à Eliminação do Titular versus Obrigações Fiscais (Artigos 16 e 18) 31
2.6 Usabilidade e Acessibilidade Digital 32
2.6.1 Heurísticas de Usabilidade de Nielsen 32
2.6.2 Acessibilidade Digital e Diretrizes WCAG 2.1 33
2.7 Padrões Arquiteturais de Software: Monólito Modular versus Microsserviços 34
3 METODOLOGIA 36
3.1 Caracterização da Pesquisa 36
3.2 Procedimentos de Coleta de Dados e Diagnóstico 37

3.3 Metodologia de Desenvolvimento Ágil (Scrum Adaptado) 38
3.3.1 *Sprint* 1 — Fundação, Autenticação e Identidade Visual (08/09 a 03/10/2026) 38
3.3.2 *Sprint* 2 — *E-commerce*, Reservas, Assistente de Agendamento e Fechamento de Qualidade (05/10 a 19/10/2026) 39
3.3.3 Práticas de Engenharia e Controle Colaborativo 40
3.4 Registro e Justificativa da Mudança de Escopo (TCC 1 para TCC 2) 41
3.5 Ambiente, Instrumentos e Uso de Ferramentas de Inteligência Artificial 42
3.6 Critérios de Validação e Homologação do Sistema 43
4 DESENVOLVIMENTO DO SISTEMA 45
4.1 Levantamento e Especificação de Requisitos 45
4.1.1 Requisitos Funcionais 45
4.1.2 Requisitos Não Funcionais 47
4.1.3 Regras de Negócio do Domínio 49
4.2 Arquitetura de Software e Tecnologias Adotadas 51
4.2.1 Diagrama Estrutural da Arquitetura 52
4.2.2 Justificativa da *Stack* Tecnológica 52
4.2.3 Organização Modular do Código-Fonte 54
4.3 Modelagem de Dados 55
4.3.1 Diagrama Entidade-Relacionamento (DER) 55
4.3.2 Dicionário de Dados e Modelo Físico 57
4.3.3 Casos de Uso e Classes do Domínio 57
4.4 Decisões de Implementação e Algoritmos do Sistema 59
4.4.1 Controle de Concorrência e Reserva Temporária de Estoque (PBI-25) 59
4.4.2 Processamento Idempotente de *Webhooks* com Assinatura HMAC (PBI-28) 61
4.4.3 *Upload* de Imagens com URLs Pré-Assinadas (PBI-17) 64
4.4.4 Assistente de Agendamento e Canal WhatsApp (PBI-31 a PBI-33) 64
4.4.5 Anonimização de Contas de Usuários em Atendimento à LGPD (PBI-40) 65
4.5 Apresentação das Interfaces do Sistema 66
4.5.1 Catálogo de Obras de Arte 66
4.5.2 Ficha Detalhada da Obra 67
4.5.3 Pedido com Reserva e Início do Pagamento 68

4.5.4 Assistente de Agendamento de Tatuagem 69
4.5.5 Portfólio de Tatuagens 70
4.5.6 Gestão Administrativa de Pedidos 71
4.5.7 Relatório de Vendas 72
5 RESULTADOS E DISCUSSÃO 74
5.1 Estratégia de Testes e Cobertura Automatizada 74
5.2 Rastreabilidade e Cobertura de Requisitos 75
5.3 Avaliação Experimental de Concorrência e Integridade de Estoque 77
5.3.1 Desenho do Experimento 77
5.3.2 Análise dos Dados e Resultados Obtidos 77
5.4 Métricas de Desempenho e Acessibilidade 78
5.4.1 Auditoria de Desempenho *Web* (Google Lighthouse) 79
5.4.2 Avaliação de Acessibilidade Digital (WCAG 2.1 AA / axe-core) 80
5.5 Validação Qualitativa com o Estabelecimento Parceiro 80
5.5.1 Síntese do Retorno do Cliente 81
5.6 Discussão dos Resultados, Dificuldades e Limitações 81
5.6.1 Validação da Hipótese de Pesquisa 82
5.6.2 Dificuldades Técnicas Vivenciadas 84
5.6.3 Limitações do Estudo 84
6 CONCLUSÃO 86
6.1 Atendimento aos Objetivos da Pesquisa 86
6.2 Avaliação da Hipótese de Pesquisa 87
6.3 Contribuições do Trabalho 88
6.3.1 Contribuições Práticas e Econômicas 88
6.3.2 Contribuições Técnicas e Acadêmicas 88
6.4 Limitações do Estudo 89
6.5 Trabalhos Futuros 90
REFERÊNCIAS 92

1 INTRODUÇÃO

1.1 Contextualização

O setor de artes plásticas e os serviços corporais de tatuagem integram a economia criativa contemporânea no Brasil. Tradicionalmente fundamentados na interação física, no atendimento presencial e na circulação territorial em polos culturais urbanos, esses modelos de negócio vêm passando por transformações impulsionadas pela digitalização dos hábitos de consumo e pela expansão dos canais digitais de divulgação (CGI.br, 2023).

O Kolô Ateliê & Estúdio localiza-se no bairro de Pinheiros, em São Paulo, combinando sob uma mesma identidade curatorial a produção, exposição e comercialização de obras físicas de arte autoral (pinturas, gravuras, esculturas e técnicas mistas) e a prestação de serviços personalizados de tatuagem artística.

Impulsionado pela divulgação de seu processo criativo por meio de plataformas como o Instagram, o Kolô ampliou sua visibilidade e a procura por seus trabalhos, conforme relatado no diagnóstico (Seção 3.2). O ateliê mantém seu espaço físico ativo em Pinheiros como ambiente de produção e atendimento presencial. Contudo, para expandir sua atuação comercial para além da limitação geográfica do bairro e profissionalizar os fluxos de venda e de contato, a estruturação de uma plataforma *web* dedicada tornou-se necessária.

Conforme apontam Laudon e Traver (2021), a evolução do comércio eletrônico exige que pequenas e médias empresas desenvolvam ecossistemas digitais próprios, capazes de assegurar a integridade de transações comerciais, a autonomia na apresentação do acervo e a comunicação assíncrona com consumidores, integrando os canais físicos e digitais do negócio.

No caso brasileiro, Sousa, Klein e Voese (2022), em pesquisa com 120 gestores de micro e pequenas empresas que vendem pela internet, verificaram que a percepção dos benefícios e dos obstáculos do comércio eletrônico é influenciada pelas pressões institucionais do ambiente em que o negócio atua. O resultado ajuda a compreender por que a adoção de canais digitais próprios tornou-se uma pauta também para pequenos negócios, como o Kolô.

1.2 Problema de Pesquisa

A despeito da demanda gerada pela divulgação virtual, o diagnóstico dos processos operacionais do Kolô revelou limitações tecnológicas nos controles internos:

a) **gestão manual de vendas e acervo:** o controle do catálogo de obras e as vendas eram realizados de forma predominantemente manual, dependendo de trocas individuais de mensagens em redes sociais e registros descentralizados. Esse modelo gerava retrabalho na conferência de disponibilidade de peças físicas e atrasos no fechamento de pedidos;

b) **ausência de catálogo digital centralizado:** interessados na aquisição de obras dependiam do envio avulso de fotos e informações por aplicativos de mensagens, sem um ambiente unificado para consulta de dados catalográficos, dimensões, técnicas de produção e certificados de autenticidade;

c) **complexidade no atendimento inicial de tatuagem:** o processo de agendamento de sessões exigia diálogos longos e repetitivos para triagem preliminar de ideias, estilos artísticos, regiões corporais, dimensões aproximadas e esclarecimento de normas de biossegurança e conformidade legal (como a maioridade civil e a realização presencial da anamnese clínica);

d) **governança de dados e conformidade:** o trânsito de dados pessoais por múltiplos canais informais de mensagens exigia a estruturação de um ambiente formalizado em conformidade com as diretrizes da Lei Geral de Proteção de Dados — LGPD, Lei nº 13.709/2018 (Brasil, 2018) —, resguardando o estabelecimento quanto à não retenção digital de dados clínicos sensíveis.

Diante desse cenário, formula-se o seguinte problema de pesquisa:

Como o desenvolvimento e a implementação de uma plataforma web integrada sob arquitetura de monólito modular podem solucionar os gargalos operacionais de controle manual de vendas de obras de arte e estruturar a triagem preliminar de

agendamentos de tatuagens do Kolô Ateliê & Estúdio, assegurando integridade transacional de estoque e conformidade com a legislação de proteção de dados?

1.3 Hipótese de Pesquisa

Para orientar a investigação, formulou-se a seguinte hipótese:

A centralização do catálogo de acervo artístico em uma plataforma web dedicada, aliada ao processamento automatizado de pedidos com reserva temporária de estoque e a um assistente determinístico em etapas para triagem e qualificação de agendamentos via WhatsApp, elimina os controles manuais de comercialização identificados no diagnóstico, previne vendas duplicadas de peças exclusivas e qualifica o atendimento inicial no Kolô Ateliê & Estúdio.

Neste trabalho, denomina-se assistente determinístico o formulário de agendamento com sequência fixa de etapas e regras de validação explícitas, sem uso de inteligência artificial, de modo que as mesmas respostas produzem sempre a mesma mensagem ao estúdio.

A hipótese fundamenta-se na capacidade da Engenharia de Software em substituir controles informais por processos digitais consistentes, ancorados em transações atômicas de banco de dados e em regras de negócio explícitas e verificáveis por testes.

1.4 Objetivo Geral

O objetivo geral desta pesquisa consiste em projetar, desenvolver e testar um sistema *web* integrado sob arquitetura de monólito modular para o Kolô Ateliê & Estúdio, provendo comércio eletrônico de obras de arte com controle transacional de estoque e um assistente determinístico de triagem de tatuagens direcionado ao WhatsApp, em conformidade com diretrizes de usabilidade, segurança da informação e privacidade da LGPD.

1.5 Objetivos Específicos

Para a consecução do objetivo geral, definiram-se os seguintes objetivos específicos:

a) **levantar e refinar os requisitos de engenharia de software:** conduzir entrevistas técnicas com a administradora e os artistas residentes do ateliê para formalizar os requisitos funcionais (RF01 a RF32), não funcionais (RNF01 a RNF24) e regras de negócio (RN01 a RN12) da versão final da aplicação (v2.2);

b) **projetar a arquitetura e a modelagem relacional:** estruturar a aplicação segundo o padrão monolítico modular cliente-servidor com Next.js 16 e PostgreSQL 17, mantendo o banco em contêiner Docker e prevendo a conteinerização da aplicação para a implantação, modelando o Diagrama Entidade-Relacionamento em 3ª Forma Normal com restrições temporais de exclusão (extensão btree_gist), projetando a camada de *proxy* reverso e TLS para a fase de implantação em produção;

c) **desenvolver o módulo de comércio eletrônico assíncrono:** implementar a vitrine de obras com carregamento otimizado de imagens (Next.js Image / WebP), carrinho persistente, *checkout* com opções de retirada no ateliê ou entrega postal com frete, integrando o processamento de pagamentos ao Mercado Pago Checkout Pro;

d) **implementar o algoritmo transacional de controle de concorrência:** projetar o mecanismo de bloqueio pessimista ordenado (SELECT ... FOR UPDATE) com reserva temporária de estoque por dez minutos e *worker* de expiração (pg-boss), prevenindo a venda duplicada (*overselling*) de obras exclusivas;

e) **desenvolver o assistente de agendamento:** criar um formulário em 8 etapas lineares no cliente que colete preferências estéticas e exija o aceite mandatório de alertas presenciais (anamnese clínica e consentimento informado), formatando o *deep link* direto para o WhatsApp comercial do estúdio (wa.me) sem retenção de dados sensíveis de saúde, em atendimento ao artigo 11 da LGPD;

f) **construir os módulos de retaguarda e conformidade:** implementar o painel administrativo de gestão de acervo, despacho postal com código de rastreamento, agenda interna de horários de tatuagem e rotina transacional de anonimização de cadastro de clientes (artigos 16 e 18 da LGPD);

g) **verificar e validar a solução computacional:** executar suítes de testes unitários e de integração com banco relacional real, realizar auditorias de desempenho (Google Lighthouse) e acessibilidade (axe-core / WCAG 2.1 AA), realizando sessão de validação assistida com a administradora e tatuadora do ateliê.

1.6 Justificativa

A justificativa do trabalho apoia-se em três pilares:

a) **dimensão prática e econômica:** do ponto de vista da gestão de pequenos empreendimentos da economia criativa, a implantação de uma plataforma própria reduz a dependência das condições comerciais e dos padrões de *layout* de plataformas terceirizadas generalistas. A automação reduz falhas de controle de peças físicas exclusivas, amplia as oportunidades de venda para além do público local e agiliza a triagem dos atendimentos de tatuagem;

b) **dimensão técnica e acadêmica:** no âmbito do Bacharelado em Ciência da Computação, o projeto aplica de forma integrada conceitos fundamentais de Engenharia de Software: arquitetura de software monolítica modular, controle de concorrência e transações ACID em bancos de dados relacionais, autenticação de *webhooks* via HMAC-SHA256, acessibilidade digital (WCAG 2.1) e esteiras de integração contínua (CI) com testes automatizados;

c) **dimensão social e regulatória:** socialmente, o projeto apoia a divulgação de artistas plásticos e tatuadores independentes atuantes em São Paulo. Sob o prisma regulatório, o trabalho demonstra como uma aplicação de médio porte pode ser concebida em conformidade com a LGPD,

implementando o princípio do *Privacy by Design* ao evitar a guarda digital desnecessária de dados sensíveis de saúde.

1.7 Estrutura do Trabalho

O trabalho organiza-se nos seguintes capítulos:

a) **capítulo 1 — introdução:** contextualiza o ateliê Kolô, delimita o problema de pesquisa, apresenta a hipótese, formula os objetivos, justificativas e a estrutura do texto;

b) **capítulo 2 — fundamentação teórica:** apresenta a base conceitual sobre comércio eletrônico na economia criativa, análise comparativa de soluções de mercado, controle de concorrência e transações, segurança em aplicações *web* (OWASP Top 10), LGPD, usabilidade, acessibilidade e estilos arquiteturais;

c) **capítulo 3 — metodologia:** detalha a classificação da pesquisa, os procedimentos de coleta, o ciclo Scrum em duas *sprints*, a estratégia de testes e a justificativa da reestruturação de escopo da versão preliminar para a v2.2;

d) **capítulo 4 — desenvolvimento do sistema:** apresenta os requisitos funcionais, não funcionais e regras de negócio, a arquitetura de software, a modelagem de dados (DER), os algoritmos centrais e as interfaces da aplicação;

e) **capítulo 5 — resultados e discussão:** documenta os resultados dos testes automatizados unitários, de integração e ponta a ponta, os experimentos de concorrência, as métricas do Google Lighthouse e axe-core, a sessão de validação com a administradora e tatuadora do Kolô e a discussão de limitações;

f) **capítulo 6 — conclusão:** avalia o grau de atendimento dos objetivos, discute a sustentação da hipótese, sintetiza as contribuições acadêmicas e práticas e aponta os direcionamentos para trabalhos futuros.

2 FUNDAMENTAÇÃO TEÓRICA

O presente capítulo estabelece as bases conceituais, científicas e tecnológicas que alicerçam a concepção e o desenvolvimento da plataforma Kolô. Abordam-se os sistemas *web* e o comércio eletrônico na economia criativa, a análise comparativa entre soluções existentes no mercado, os mecanismos de controle de concorrência e integridade transacional, os pilares de segurança na *web* e conformidade com a Lei Geral de Proteção de Dados (LGPD), as diretrizes de usabilidade e acessibilidade digital, e a discussão arquitetural entre monólitos modulares e microsserviços.

2.1 Sistemas *Web* e Comércio Eletrônico na Economia Criativa

Os sistemas de informação são conceituados por Laudon e Laudon (2014) como um conjunto integrado de componentes computacionais e humanos que coletam, armazenam, processam e distribuem dados com o intuito de subsidiar o planejamento, a tomada de decisões e o controle operacional nas organizações. Com a consolidação da infraestrutura global da internet e o aprimoramento dos protocolos de hipertexto, essa disciplina convergiu para os sistemas de informação *web* — aplicações distribuídas baseadas na arquitetura cliente-servidor que viabilizam o processamento remoto e a interação de usuários em tempo real por meio de navegadores universais (Tanenbaum; Wetherall, 2011).

No contexto econômico, Turban *et al.* (2015) definem o comércio eletrônico (*e-commerce*) como a realização de transações comerciais, compra e venda de mercadorias e prestação de serviços mediadas por redes de computadores. Enquanto os grandes conglomerados varejistas exploram modelos de catálogo massificado de bens de consumo padronizados, a digitalização dos setores artesanais e autorais — englobados pelo conceito de economia criativa — impõe particularidades substantivas.

A pesquisa TIC Empresas, conduzida pelo Comitê Gestor da Internet no Brasil (CGI.br, 2023), acompanha o uso de tecnologias digitais, inclusive o comércio eletrônico, pelas empresas brasileiras; nesse contexto, a adoção de canais próprios de venda amplia a capacidade de relacionamento direto de pequenos negócios com seus consumidores. No caso específico de um ateliê de arte física e estúdio de

tatuagem, o modelo de negócios transcende o varejo tradicional: cada obra física representa uma peça única e autoral, frequentemente de tiragem unitária e alto valor agregado estético, cuja venda exige transparência técnica (dimensões, pigmentos, suporte) e confiança transacional (Laudon; Traver, 2021).

Gefen, Karahanna e Straub (2003) demonstraram que, nas compras on-line, a confiança no vendedor pesa tanto quanto a utilidade e a facilidade de uso percebidas, e que essa confiança se constrói, entre outros fatores, pela percepção de mecanismos de segurança no site e por uma interface típica e fácil de usar. No Kolô, esses conceitos se aplicam à delegação do pagamento ao ambiente de um provedor reconhecido e à apresentação clara das políticas da loja.

Ademais, ao contrário de plataformas que operam como *marketplaces* multifacetados abertos a terceiros — que demandam esquemas complexos de divisão de repasses (*split payment*) e gestão de disputa entre múltiplos vendedores (Evans; Schmalensee, 2016) —, o Kolô adota o modelo de loja autoral centralizada. Nesse modelo, o ateliê gerencia o acervo físico de seus artistas residentes, necessitando de uma vitrine coesa que projete sua identidade e ofereça uma jornada de *checkout* sem etapas redundantes.

Essa escolha dialoga com a literatura sobre o mercado de arte. Ricucci e Blank (2026) analisam por que as plataformas digitais não eliminaram os intermediários desse mercado, no qual as galerias continuam centrais na atribuição de valor às obras. No Kolô, o próprio ateliê exerce esse papel de intermediação entre seus artistas e os compradores, agora também no ambiente digital.

2.2 Trabalhos Relacionados e Comparação entre Soluções de Mercado

A modelagem de um sistema dedicado para o Kolô fundamenta-se na identificação das lacunas apresentadas pelas ferramentas comerciais atualmente disponíveis. A operação do ateliê é caracterizada pela convivência de duas frentes de receita: a comercialização assíncrona de bens físicos tangíveis (obras de arte) e a prestação personalizada de serviços corporais presenciais (sessões de tatuagem).

Para compreender o panorama das ferramentas disponíveis e justificar a construção de uma solução dedicada, realizou-se uma análise comparativa

exploratória entre as principais categorias de plataformas do mercado, sintetizada no Quadro 2.1.

Quadro 2.1 — Análise Comparativa entre Soluções de Mercado e a Plataforma Kolô

Critério	**Shopify (Shopify, [2026])**	**Artsy (Artsy, [2026])**	**Booksy (Booksy, [2026])**	**Tattoodo (Tattoodo, [2026])**	**Plataforma Kolô**
Categoria de mercado	*E-commerce* generalista	*Marketplace* de arte	Agenda de serviços de beleza	Busca e reserva de tatuadores	Solução dedicada integrada
Venda de obras físicas com estoque unitário	Controle de quantidade em estoque (Shopify)	Venda por parceiros aprovados (galerias, instituições, leilões, feiras)	Não se aplica	Não identificado	Estoque unitário com baixa transacional
Reserva temporária no *checkout*	Não identificado	Não identificado	Não se aplica	Não se aplica	Reserva de 10 min no PostgreSQL
Portfólio artístico segmentado	Não é o foco (catálogo de produtos)	Não é o foco (obras de arte)	Portfólios e avaliações de profissionais	Navegação por artistas e estilos, com avaliações	Filtros por artista, estilo e região
Triagem de tatuagem via WhatsApp	Não identificado	Não identificado	Não identificado	Não identificado	Assistente com *deep link* estruturado
Identidade visual autoral integrada	Não identificado	Identidade do *marketplace*	Não identificado	Identidade da plataforma	*Design system* e domínio próprios

Fonte: Elaborado pelos autores (2026), com base nas páginas citadas em cada coluna.

Nota: “Não identificado” indica que a informação não consta nas páginas consultadas.

A análise comparativa, limitada ao que as páginas consultadas informam, evidencia que:

a) a plataforma de comércio eletrônico generalista consultada (Shopify) oferece controle de quantidade em estoque, mas as páginas consultadas não descrevem reserva temporária durante o *checkout* nem fluxo de agendamento de serviços. A adequação dessa categoria de plataforma à venda de peças únicas (Q = 1) sob compras simultâneas não foi identificada, e o comportamento do Kolô nesse cenário é tratado, no Capítulo 5, como requisito a ser demonstrado no próprio sistema;

b) o *marketplace* de arte consultado condiciona a venda à candidatura como parceiro (galeria, instituição, leilão, feira ou outro), o que limita o uso por um

ateliê independente que deseja manter sua própria vitrine, e não contempla serviços de tatuagem;

c) as plataformas de agendamento consultadas (Booksy e Tattoodo) priorizam a reserva direta de horários com profissionais, com portfólios e avaliações, e não descrevem uma etapa estruturada de triagem do projeto de tatuagem nem o encaminhamento ao WhatsApp. O tratamento de dados de saúde por essas plataformas não foi avaliado neste trabalho: a decisão do Kolô de não armazenar a anamnese decorre do artigo 11 da LGPD (Seção 2.5.2), e não de uma deficiência verificada nas demais soluções.

No âmbito acadêmico, Lee e Lee (2019) estudaram a Saatchi Art, plataforma digital de comercialização de arte, e observaram que ela reduz barreiras para compradores iniciantes, como a distância geográfica e o ambiente intimidador das galerias, mas que a participação dos usuários na valorização das obras permanece limitada e orientada pela curadoria. O resultado reforça a importância de uma identidade curatorial própria, como a que o Kolô mantém em sua vitrine.

Assim, a concepção do sistema Kolô justifica-se por unificar a comercialização de acervo físico e a triagem assistida de serviços corporais em um único ambiente sob controle do estabelecimento.

2.3 Controle de Concorrência e Integridade Transacional

Uma transação é uma sequência de operações tratada pelo banco de dados como uma única unidade de trabalho. Silberschatz, Korth e Sudarshan (2020) descrevem as quatro propriedades que ela deve preservar, reunidas na sigla ACID. Pela atomicidade, todas as operações são efetivadas ou nenhuma o é. Pela consistência, o banco passa de um estado válido a outro. Pelo isolamento, transações simultâneas não interferem entre si. Pela durabilidade, uma transação confirmada sobrevive a falhas posteriores.

Em sistemas *web*, o isolamento é a propriedade mais exposta, porque o servidor processa requisições em paralelo. Berenson *et al.* (1995), em sua crítica aos níveis de isolamento do padrão ANSI SQL, sistematizaram as anomalias que surgem quando o isolamento é incompleto. Na atualização perdida, duas transações leem o

mesmo valor e gravam alterações baseadas nessa leitura, e a segunda anula a primeira (Kleppmann, 2017). Na leitura suja, uma transação lê um dado de outra que ainda não foi confirmada (*commit*) e que pode ser desfeita (*rollback*). Na leitura não repetível, a mesma linha apresenta valores diferentes em duas leituras sucessivas. Nos fantasmas, uma consulta repetida passa a retornar linhas inseridas ou removidas por outra transação. Para o Kolô, a atualização perdida é a mais grave: se duas transações leem estoque igual a 1 e ambas registram a baixa, a peça única é vendida duas vezes. Esse problema é chamado de *overselling*: a venda de mais unidades do que o estoque disponível.

Kleppmann (2017) contrapõe duas abordagens. No bloqueio otimista, a transação lê o registro sem travá-lo e, ao gravar, verifica se outra transação o alterou; havendo conflito, ela é abortada e precisa ser reiniciada. No bloqueio pessimista, a transação trava o registro já na leitura, e as demais aguardam sua conclusão. Segundo o autor, a abordagem otimista funciona bem quando há pouca disputa, mas perde eficiência quando muitas transações disputam os mesmos dados, pois mais delas precisam ser abortadas.

Em uma obra com estoque igual a 1 (Q = 1), toda a disputa se concentra no único exemplar, e a rejeição tardia do bloqueio otimista recai sobre o comprador. O conflito só seria detectado na gravação final, e a compra seria recusada no último passo, depois de revisado o pedido. Com o bloqueio pessimista, a disputa é resolvida no início do *checkout*, etapa de finalização da compra, antes do pagamento. O custo é a espera pela liberação da trava, restrita às transações que disputam a mesma obra. No Kolô, a regra que impede a venda duplicada (RN04, Seção 4.1.3) adota o bloqueio pessimista de linhas do PostgreSQL 17, dentro de uma única transação de reserva (ver Seção 4.4.1).

O bloqueio pessimista traz outro risco, o impasse (*deadlock*), em que transações esperam indefinidamente por travas mantidas umas pelas outras. Isso ocorre quando a transação A trava a obra 1 e aguarda a obra 2, enquanto a transação B trava a obra 2 e aguarda a obra 1. Silberschatz, Korth e Sudarshan (2020) apresentam a ordenação dos recursos como forma de prevenção: se todas as transações adquirem as travas na mesma ordem, não se forma um ciclo de espera. Por isso, o Kolô ordena os identificadores das obras do carrinho antes do bloqueio (ver Seção 4.4.1). Uma transação bem isolada protege os dados contra conflitos entre

usuários legítimos; a Seção 2.4 trata da proteção contra quem tenta explorar falhas da aplicação.

2.4 Segurança da Informação em Aplicações *Web* (OWASP Top 10)

O OWASP Top 10 reúne os riscos de segurança considerados mais críticos para aplicações *web* (OWASP, 2021). Em uma loja que recebe pagamentos, esses riscos são concretos. Uma injeção pode expor cadastros e pedidos, e um código malicioso pode agir na sessão do administrador. Uma falha de autenticação pode entregar a terceiros o controle de preços e estoques. Uma notificação de pagamento forjada pode marcar como pago um pedido não quitado. Gefen, Karahanna e Straub (2003) mostraram que a percepção de mecanismos de segurança contribui para a confiança do consumidor nas compras on-line.

2.4.1 Injeção de Código e Injeção de SQL (A03:2021 — *Injection*)

A injeção de SQL ocorre quando dados do usuário são concatenados ao texto de um comando enviado ao banco, que deixa de distinguir o dado do comando. Um atacante pode, assim, ler ou alterar registros sem autorização e contornar a autenticação (Anderson, 2020). A defesa é a consulta parametrizada, em que a estrutura do comando segue separada dos valores, tratados apenas como dados.

No Kolô, essa separação é feita pelo Prisma, um mapeador objeto-relacional (ORM) que envia as consultas ao PostgreSQL de forma parametrizada (RNF04, Quadro 4.2). A consulta de bloqueio da reserva, escrita diretamente em SQL, também recebe os identificadores como parâmetros (ver Seção 4.4.1). Os esquemas de validação Zod (RNF09) têm outra função: restringem o tipo, o tamanho e o formato das entradas. Essa validação rejeita dados malformados, mas a proteção contra a injeção decorre da parametrização das consultas.

2.4.2 *Cross-Site Scripting* (A03:2021 — XSS) e Proteção de Borda

O *Cross-Site Scripting* (XSS) ocorre quando dados não confiáveis entram na página sem tratamento e o navegador os executa como código, com os privilégios da sessão da vítima (Anderson, 2020). Na loja, um ataque desse tipo poderia operar o

painel administrativo com a sessão do administrador. A primeira barreira é o escape: o React 19 converte em texto os caracteres especiais dos valores inseridos nos componentes (Banks; Porcello, 2020; Stefanov, 2016). A segunda é a *Content Security Policy* (CSP), cabeçalho que indica ao navegador quais códigos a página pode executar.

Weichselbaum *et al.* (2016) analisaram 26.011 políticas CSP distintas em uso na *web*. Os autores identificaram falhas que permitiam contornar 94,72% delas e verificaram que 75,81% empregavam listas de domínios autorizados que possibilitavam esse contorno. Os números indicam que autorizar domínios inteiros oferece proteção limitada. Como alternativa, os autores propuseram políticas baseadas em *nonce*, valor aleatório gerado a cada resposta e usado uma única vez, combinadas com a diretiva *strict-dynamic*. Nesse modelo, só são executados os códigos que apresentam o *nonce* da resposta atual, que um código injetado não conhece. O Kolô adota essa proposta e gera um *nonce* novo a cada requisição (RNF05 e RNF07, Quadro 4.2).

2.4.3 Autenticação Segura com *Hash* scrypt (A07:2021 — *Identification and Authentication Failures*)

Senhas não devem ser armazenadas em texto claro, pois um vazamento do banco exporia as credenciais. Em seu lugar, armazena-se o resultado de uma função de derivação de chaves, como o scrypt (Percival; Josefsson, 2016), projetado para exigir muita memória e processamento a cada cálculo. Esse custo encarece os ataques de força bruta, que testam grande número de senhas candidatas, sobretudo quando executados em paralelo. O *salt*, valor aleatório individual combinado à senha, faz senhas iguais gerarem resultados diferentes e inutiliza tabelas de resultados pré-calculados. No Kolô, a biblioteca Better Auth aplica o scrypt com *salt* individual (RNF03, Quadro 4.2). O cuidado é relevante porque a conta de administrador controla preços, estoques e pedidos.

A sessão autenticada é identificada por um *cookie*, dado que o navegador guarda e reenvia ao servidor a cada requisição; quem o obtém pode agir em nome do usuário. O atributo HttpOnly impede que códigos da página leiam o *cookie*, o que limita o efeito de um ataque XSS sobre a sessão. O atributo Secure restringe o envio do

cookie a conexões HTTPS; no Kolô, ele é ativado em produção, cujo HTTPS está projetado (RNF01). O atributo SameSite=Lax bloqueia o envio na maior parte das requisições vindas de outros sites. Com isso, reduz-se o risco de falsificação de requisição entre sites (CSRF), em que uma página externa induz o navegador a executar uma ação autenticada (RNF06).

2.4.4 Autenticidade e Idempotência de *Webhooks* Criptográficos (HMAC-SHA256)

Um *webhook* é uma notificação HTTP enviada automaticamente por um serviço externo quando ocorre um evento. É por esse meio que o *gateway* de pagamento, serviço que processa as transações financeiras, informa ao Kolô a situação de um pagamento. Como o endereço receptor é público, uma notificação forjada poderia levar o sistema a registrar como pago um pedido não quitado.

O HMAC (*Hash-based Message Authentication Code*), especificado na RFC 2104 (Krawczyk; Bellare; Canetti, 1997), combina uma função de dispersão criptográfica com uma chave secreta compartilhada. O remetente calcula um código a partir da mensagem e da chave, e o receptor refaz o cálculo e compara os resultados. A coincidência indica que a mensagem veio de quem conhece a chave e não foi alterada no trajeto. A função de dispersão adotada no Kolô é a SHA-256.

A assinatura de cada notificação é verificada com o validador oficial do Mercado Pago, e notificações inválidas ou defasadas são rejeitadas com código HTTP 401. Como a mesma notificação pode chegar mais de uma vez, uma restrição de unicidade no banco impede que um evento já registrado altere o pedido novamente (ver Seção 4.4.2). As medidas desta seção protegem a aplicação contra ataques; a Seção 2.5 trata de quais dados pessoais ela deve coletar e por quanto tempo deve mantê-los.

2.5 Privacidade e Conformidade com a LGPD (Lei nº 13.709/2018)

A Lei Geral de Proteção de Dados Pessoais (LGPD), Lei nº 13.709/2018, regula o tratamento de dados de pessoas naturais, inclusive nos meios digitais (Brasil, 2018). Três de seus pontos afetam o projeto do Kolô e são examinados a seguir quanto à exigência legal, ao risco para o ateliê e à decisão de projeto.

2.5.1 Princípios de Minimização e Finalidade (Artigo 6º)

O art. 6º, III, da LGPD estabelece o princípio da necessidade, que determina a "limitação do tratamento ao mínimo necessário para a realização de suas finalidades" (Brasil, 2018, art. 6º, III). Para o ateliê, coletar dados além do necessário ampliaria o volume de informações expostas em um incidente de segurança, sem benefício para a venda. Por isso, o cadastro de clientes restringe-se aos dados de contato e entrega: nome completo, e-mail, telefone e endereço de entrega (RNF17, Quadro 4.2). Os dados de pagamento são coletados no ambiente do *gateway*, e não no servidor do ateliê (RNF10). Essa delegação afasta da aplicação o tratamento de dados de cartão, objeto do padrão PCI DSS (PCI Security Standards Council, 2022). A orientação corresponde à privacidade desde a concepção (*Privacy by Design*).

Camêlo e Alves (2023) observam que a LGPD é de difícil interpretação e conversão em requisitos de software. Por isso, propõem um guia para especificar requisitos de privacidade desde as fases iniciais do desenvolvimento. No Kolô, essa preocupação aparece nos requisitos não funcionais de privacidade e nas decisões descritas nas Seções 2.5.2 e 2.5.3. Tais medidas, por si sós, não atestam a conformidade integral com a lei.

2.5.2 Tratamento de Dados Sensíveis de Saúde na Tatuagem (Artigo 11)

A LGPD inclui entre os dados pessoais sensíveis o "[...] dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural" (Brasil, 2018, art. 5º, II) e determina que o tratamento desses dados "somente poderá ocorrer nas seguintes hipóteses" enumeradas em lei (Brasil, 2018, art. 11). A tatuagem exige anamnese, isto é, o levantamento prévio de informações clínicas, como alergias, histórico de cicatrização, uso de anticoagulantes e afecções de pele. Se essas informações fossem armazenadas na aplicação, o ateliê assumiria as obrigações próprias do tratamento de dados sensíveis. Um incidente de segurança atingiria justamente a categoria de dados que a lei protege com mais restrições.

A decisão de projeto foi não coletar dados de saúde no sistema. O assistente de agendamento reúne apenas dados da solicitação, como artista, estilo, região do corpo, dimensão e data de preferência. Esse conteúdo compõe uma mensagem ao

WhatsApp do estúdio e não é armazenado; o sistema guarda apenas registros técnicos de controle de frequência de requisições (RNF18). Antes do envio, o usuário marca caixas de seleção obrigatórias em que declara saber que a anamnese e o termo de consentimento serão preenchidos e assinados presencialmente no ateliê. Assim, a triagem permanece possível sem que dados de saúde entrem na aplicação (ver Seção 4.4.4).

2.5.3 Direito à Eliminação do Titular versus Obrigações Fiscais (Artigos 16 e 18)

A LGPD trata a eliminação de dados pessoais em dois dispositivos complementares. O art. 18 assegura ao titular, mediante requisição, a “eliminação dos dados pessoais tratados com o consentimento do titular, exceto nas hipóteses previstas no art. 16 desta Lei” (Brasil, 2018, art. 18, VI). O art. 16, por sua vez, estabelece que “Os dados pessoais serão eliminados após o término de seu tratamento, no âmbito e nos limites técnicos das atividades” e autoriza a conservação para o “cumprimento de obrigação legal ou regulatória pelo controlador” (Brasil, 2018, art. 16, I).

No Kolô, os dados de clientes não são tratados com base no consentimento. Conforme a política de privacidade da plataforma (RF08), a conta, os pedidos, o pagamento e a entrega apoiam-se na execução de contrato, hipótese prevista para quando o tratamento é “necessário para a execução de contrato ou de procedimentos preliminares relacionados a contrato do qual seja parte o titular, a pedido do titular dos dados” (Brasil, 2018, art. 7º, V). Por isso, o direito do art. 18, VI não alcança diretamente esses dados.

Ainda assim, a plataforma permite que o titular encerre a própria conta a qualquer momento. O encerramento marca o término do tratamento para fins de relacionamento com o cliente, e o art. 16 passa a orientar a decisão: os dados que identificam o titular são eliminados, enquanto o registro das vendas é conservado para atender à legislação fiscal.

A decisão de projeto foi anonimizar os dados cadastrais na exclusão da conta (RN12, Seção 4.1.3). Nome, e-mail, telefone e endereço são substituídos ou removidos, e credenciais e sessões são apagadas. Os pedidos e seus valores permanecem para fins contábeis, com o endereço de entrega reduzido a cidade e UF

(ver Seção 4.4.5). Cabe ressalvar que os pedidos preservados mantêm itens, valores e datas, e a possibilidade de reidentificação a partir desse conjunto não foi avaliada neste trabalho. Definidos os limites de coleta e de guarda dos dados do usuário, a Seção 2.6 trata da forma como esse usuário interage com o sistema.

2.6 Usabilidade e Acessibilidade Digital

O valor de uma loja on-line depende também da facilidade com que pessoas diferentes a utilizam, em dispositivos diversos e com capacidades distintas. Gefen, Karahanna e Straub (2003) indicaram que a facilidade de uso percebida contribui para a confiança nas compras on-line.

2.6.1 Heurísticas de Usabilidade de Nielsen

A avaliação heurística foi apresentada por Nielsen e Molich (1990) como um método de inspeção em que avaliadores examinam a interface à luz de princípios gerais de usabilidade. Os autores mostraram que um avaliador isolado identifica apenas parte dos problemas e que a combinação de três a cinco avaliadores produz resultados melhores. Neste trabalho, as heurísticas foram empregadas como diretrizes de projeto, e não como método de avaliação. Os parágrafos seguintes descrevem, portanto, intenções de projeto, e não resultados de inspeção. Entre as dez heurísticas de usabilidade propostas por Nielsen (1994), quatro orientaram diretamente as telas do Kolô.

A visibilidade do estado do sistema prevê que a interface mantenha o usuário informado sobre o que está acontecendo. Na tela do pedido, um contador mostra o tempo restante da reserva de dez minutos (RN03) para iniciar o pagamento (ver Seção 4.5.3). No assistente de agendamento, indicadores de etapa mostram em que ponto do preenchimento o usuário está.

A correspondência entre o sistema e o mundo real recomenda usar a linguagem do usuário, e não termos da computação. No catálogo e na ficha das obras, a interface emprega o vocabulário de ateliês e estúdios, como ficha técnica, técnica mista, tiragem e *blackwork* (ver Seções 4.5.1 e 4.5.2). *Blackwork* designa a tatuagem feita em áreas de preto sólido.

A heurística de consistência e padrões indica que palavras e ações equivalentes devem ter o mesmo significado em toda a interface. No Kolô, cabeçalhos, botões de ação e componentes de navegação seguem um conjunto comum de padrões visuais (*design system*). A intenção é que o comprador que aprendeu a usar o catálogo reconheça os mesmos elementos no carrinho e no pedido.

A prevenção de erros recomenda evitar que o problema ocorra, em vez de apenas informá-lo depois. No assistente de agendamento, a interface verifica a coerência das datas e impede o envio de formulários incompletos. No *checkout*, etapa de finalização da compra, uma obra esgotada deixa de aceitar adições ao carrinho (RN11), e o pagamento de itens sem estoque é bloqueado antes da chamada ao *gateway* de pagamento. Essas medidas reduzem o risco de o comprador pagar por uma peça indisponível.

2.6.2 Acessibilidade Digital e Diretrizes WCAG 2.1

As Diretrizes de Acessibilidade para Conteúdo *Web* (WCAG 2.1), do consórcio W3C, organizam seus critérios em quatro princípios: perceptível, operável, compreensível e robusto (W3C, 2018). Em um comércio eletrônico, cada princípio corresponde a uma barreira que pode impedir parte do público de comprar.

Pelo princípio perceptível, a informação deve ser apresentada de forma que todos possam percebê-la. Em uma loja de obras visuais, a imagem é o principal conteúdo do produto, e uma pessoa cega depende do texto alternativo para saber o que está à venda. O mesmo princípio inclui a razão mínima de contraste de 4,5:1 para textos de tamanho normal. Pelo princípio operável, a interface deve funcionar por teclado, com foco visível; sem isso, quem não usa o mouse pode não concluir a compra. Pelo princípio compreensível, conteúdo e comportamento devem ser previsíveis, o que inclui formulários de cadastro e de pagamento com instruções claras. Pelo princípio robusto, o conteúdo deve ser interpretado de forma confiável por navegadores e tecnologias assistivas, o que depende de elementos semânticos do HTML.

No Kolô, o requisito de acessibilidade adota o nível AA da WCAG 2.1 como referência (RNF21, Quadro 4.2). A verificação da navegação por teclado e do foco visível nos fluxos principais permanece pendente, conforme a Seção 5.4.2. A

presença de textos alternativos também não substitui a avaliação da adequação das descrições e da navegação com leitores de tela.

A verificação automática, contudo, não esgota a avaliação de acessibilidade. Vigo, Brown e Conway (2013) compararam ferramentas automáticas com a avaliação de especialistas e mostraram que elas cobrem apenas parte dos critérios da WCAG. Guimarães (2016) avaliou sites brasileiros de comércio eletrônico com ferramentas automáticas e com usuários cegos. Nenhum dos sites atingia o nível mínimo recomendado pela WCAG 2.0, e as barreiras de navegação chegaram a impedir a conclusão de uma compra. Assim, a ausência de violações apontadas por uma ferramenta não equivale a uma loja acessível (ver Seção 5.6.3). Segurança, privacidade, usabilidade e acessibilidade dependem da organização interna do sistema, e a Seção 2.7 discute a arquitetura escolhida para sustentá-las.

2.7 Padrões Arquiteturais de Software: Monólito Modular versus Microsserviços

A escolha do padrão arquitetural constitui uma decisão relevante para a viabilidade, custo e manutenibilidade de uma aplicação *web* (Pressman; Maxim, 2021; Sommerville, 2019). A literatura discute a divisão entre microsserviços distribuídos e sistemas monolíticos (Newman, 2015).

A arquitetura de microsserviços propõe a divisão da aplicação em serviços autônomos, cada qual com banco de dados próprio, comunicando-se através da rede. Conforme apontam Richards e Ford (2020), embora os microsserviços ofereçam escalabilidade independente para organizações com múltiplas equipes, introduzem complexidades adicionais:

a) latência cumulativa de rede e necessidade de gerenciar falhas parciais;

b) complexidade na coordenação de transações distribuídas entre bases de dados isoladas;

c) demanda por infraestrutura adicional para roteamento, observabilidade e orquestração de contêineres.

Em contrapartida, a arquitetura monolítica modular reúne as camadas de negócio e apresentação em uma única base de código implantada como uma unidade

executável, organizando internamente as responsabilidades por meio de fronteiras de módulos delimitadas (Sommerville, 2019).

Em revisão sistemática recente, Al-Qora'n e Al-Said Ahmad (2025) caracterizam o monólito modular como uma arquitetura híbrida, posicionada entre o monólito tradicional e os microsserviços, que combina a simplicidade operacional do primeiro com modularidade e manutenibilidade. Os autores apontam, porém, a escassez de comparações empíricas entre as arquiteturas; por isso, a escolha é apresentada aqui como adequada ao contexto do Kolô, e não como superior em qualquer cenário.

Para o escopo do Kolô, a arquitetura monolítica modular mostrou-se mais adequada pelas seguintes razões técnicas:

a) **transações ACID locais:** o controle de reserva temporária de obras (Q = 1) exige atomicidade imediata entre o decremento de estoque e a gravação da reserva. No monólito sobre o PostgreSQL, a operação é resolvida dentro de uma única transação local, com bloqueio das linhas disputadas (Seção 2.3), sem dependência de consistência eventual;

b) **eliminação de divergências de contrato:** o uso do Next.js 16 com TypeScript em modo estrito compartilha modelos de dados e esquemas de validação Zod diretamente entre as Server Actions (servidor) e a interface reativa (cliente) (Node.js, 2026; Vercel, 2026);

c) **custo operacional e simplicidade de manutenção:** o sistema completo — abrangendo servidor *web*, banco relacional e fila de tarefas assíncronas — pode ser operado em uma única máquina virtual privada (VPS) conteinerizada, reduzindo a complexidade de manutenção.

Assim, o monólito modular consolidou-se como a abordagem arquitetural coerente com as dimensões e requisitos do projeto.

3 METODOLOGIA

O presente capítulo descreve os procedimentos metodológicos, os instrumentos técnicos e as práticas de Engenharia de Software adotadas para a concepção, o desenvolvimento e a avaliação da plataforma Kolô.

O capítulo apresenta o processo de pesquisa-ação, as rotinas de coleta junto à administradora do estabelecimento parceiro, a dinâmica das *sprints*, a justificativa da reestruturação de escopo entre o TCC 1 e o TCC 2 e os ambientes computacionais empregados.

3.1 Caracterização da Pesquisa

A condução metodológica deste estudo classifica-se segundo quatro eixos fundamentais estabelecidos pela literatura científica (Gil, 2017; Prodanov; Freitas, 2013):

a) **quanto à natureza:** trata-se de uma pesquisa aplicada, pois orienta-se à resolução de um problema prático e delimitado de engenharia de software — a superação dos controles manuais de vendas de arte e a estruturação do fluxo de agendamentos no Kolô Ateliê & Estúdio —, visando gerar um produto tecnológico funcional;

b) **quanto à abordagem do problema:** classifica-se como qualitativa. O foco primordial reside na compreensão dos processos internos de trabalho, na análise das necessidades dos atores envolvidos (clientes, tatuadores e gestores) e na avaliação funcional das interfaces desenvolvidas, prescindindo de amostragem estatística populacional;

c) **quanto aos objetivos:** define-se como pesquisa exploratória, ao promover o mapeamento preliminar das rotinas operacionais do ateliê, o estudo comparativo de ferramentas correlatas e a investigação técnica de soluções computacionais contemporâneas (como o Next.js 16, transações pessimistas e contêineres Docker);

d) **quanto aos procedimentos técnicos:** adota o delineamento da pesquisa-ação (*action research*). Conforme conceituado por Gil (2017), a pesquisa-

ação pressupõe a participação ativa e colaborativa dos pesquisadores na análise do problema diagnosticado, na concepção da solução e na intervenção direta sobre o ecossistema da organização parceira, integrando desenvolvimento técnico e avaliação participativa.

3.2 Procedimentos de Coleta de Dados e Diagnóstico

A etapa de levantamento e diagnóstico realizou-se em conjunto com a administradora e tatuadora do Kolô Ateliê & Estúdio, Melanie Schwark, e com os demais tatuadores residentes, por meio de entrevistas semiestruturadas e observação das rotinas de atendimento.

O roteiro de coleta investigou as seguintes dimensões operacionais:

a) **fluxo de comercialização de obras:** identificou-se que as fotografias das peças eram publicadas de forma isolada em redes sociais. Os interessados entravam em contato por mensagens diretas, nas quais o atendente verificava se a peça ainda estava fisicamente disponível no ateliê em Pinheiros, calculava o frete manualmente em sites de logística e repassava chaves Pix. Esse processo gerava demora no atendimento e risco de desencontros de disponibilidade no acervo físico;

b) **fluxo de atendimento de tatuagem:** mapeou-se o tempo dedicado pelos artistas à triagem inicial de mensagens em aplicativos. Grande parte do diálogo envolvia responder repetidamente sobre dimensões mínimas, estilos dominados pelo profissional e orientações de maioridade e biossegurança;

c) **retirada presencial e localização:** confirmou-se a manutenção do espaço físico no bairro de Pinheiros como polo de criação e atendimento presencial, estabelecendo-se a necessidade de prever tanto o envio postal com frete quanto a opção de retirada presencial sem custo no ateliê;

d) **conformidade legal:** averiguou-se a necessidade de resguardar o ateliê quanto à Lei Geral de Proteção de Dados (LGPD), determinando que prontuários de anamnese de saúde fossem tratados de forma exclusivamente presencial.

As informações colhidas nas entrevistas foram sistematizadas e convertidas na matriz inicial de requisitos e regras de negócio da aplicação.

3.3 Metodologia de Desenvolvimento Ágil (Scrum Adaptado)

O desenvolvimento do software estruturou-se sob os princípios do Scrum (Schwaber; Sutherland, 2020), ajustado ao ritmo da equipe multidisciplinar composta por cinco integrantes do curso de Ciência da Computação: Caio Scorsoni Martins Oliveira, Caio Vinicius Luiz Alves, Guilherme dos Santos Salustiano, Gustavo Henrique Rodrigues de Magalhães e Robert Estevan da Silva Junior.

A adaptação do Scrum limitou-se aos artefatos e práticas descritos a seguir: *backlog* do produto organizado em itens (*Product Backlog Items*, PBIs) com prioridade (P0 e P1), definição de pronto comum aos itens, *sprints* com meta, revisão de código por pares e integração contínua. O acompanhamento ocorreu em reuniões semanais, às segundas-feiras, para discutir o andamento das entregas. Os demais eventos do Scrum (planejamento formal, reuniões diárias e retrospectiva) não foram conduzidos de forma sistemática, de modo que o método foi seguido de maneira flexível, e não rigorosa.

A execução do projeto organizou-se em duas *sprints*. A *Sprint* 1 foi planejada para uma semana de fundação (PBIs 01 a 15, conforme o planejamento em docs/SPRINT-1.md), mas, na execução, estendeu-se de 08/09 a 03/10/2026; nesse intervalo também se consolidou a revisão do escopo para a versão 2.2 (21/09). A *Sprint* 2, planejada para o período de 05 a 18/10/2026 e concluída em 19/10 com a integração do PBI-48, reuniu os demais PBIs (16 a 48), exceto os de implantação e homologação final (PBIs 46 e 47), previstos para a etapa subsequente. A divergência entre o prazo planejado e o executado na *Sprint* 1 é discutida na Seção 5.6.2.

3.3.1 *Sprint* 1 — Fundação, Autenticação e Identidade Visual (08/09 a 03/10/2026)

A *Sprint* 1 dedicou-se à estruturação dos alicerces técnicos do sistema (PBIs 01 a 15), abrangendo:

a) revisão dos requisitos e redesenho do modelo entidade-relacionamento (PBIs 01 e 02);

b) repositório com proteções de integração, aplicação Next.js base e ambiente em contêineres Docker com PostgreSQL 17 (PBIs 03 a 05);

c) esquema do Prisma ORM, migração inicial e carga de dados iniciais (PBIs 06 a 08);

d) identidade visual, *tokens* de *design* e *layout* base (PBIs 09 e 10);

e) autenticação com senhas derivadas em scrypt e sessões persistidas no banco via Better Auth, com controle de acesso por papéis — Cliente, Artista e Administrador (PBI-11, RF06);

f) cadastro, *login* e *logout* com sessão revogável, recuperação de senha e edição de perfil (PBIs 12 a 15, RF01 a RF04).

3.3.2 *Sprint* 2 — *E-commerce*, Reservas, Assistente de Agendamento e Fechamento de Qualidade (05/10 a 19/10/2026)

A *Sprint* 2 implementou os fluxos transacionais e de valor da plataforma:

a) **acervo e vitrine (PBIs 16 a 21):** gestão de artistas, estilos e *tags* (PBI-16, RF28), *upload* de mídias com geração de URLs pré-assinadas e miniaturas (PBI-17), CRUD de obras de arte (PBI-18), catálogo em grade 2D com ordenação e paginação (PBI-19), ficha detalhada da obra (PBI-20) e página inicial institucional (PBI-21);

b) **comércio e *checkout* (PBIs 24 a 29 e PBI-42):** carrinho persistente (PBI-24), algoritmo de reserva temporária de 10 minutos com bloqueio pessimista (PBI-25), *checkout* com opções de retirada presencial em Pinheiros ou entrega postal (PBIs 26 e 42), integração com Mercado Pago Checkout Pro (PBI-27), confirmação de pagamentos via *webhook* idempotente com validação de assinatura (PBI-28) e painel de pedidos do cliente (PBI-29);

c) **tatuagem e agendamento (PBIs 31 a 37):** assistente público em 8 etapas com validação declarativa (PBI-31), caixas de conformidade presencial obrigatória (PBI-32), gerador de *link* estruturado para o WhatsApp (PBI-33), agenda interna de horários com restrição de não sobreposição (PBI-34) e galeria de portfólio com filtros (PBIs 35 a 37);

d) **conformidade e retaguarda (PBIs 38 a 40 e PBI-48):** perfil administrativo de clientes (PBI-38), parametrização de configurações institucionais do estúdio (PBI-39), rotina transacional de exclusão e anonimização de dados conforme a LGPD (PBI-40) e painel de indicadores com relatório de vendas por período (PBI-48, RF32);

e) **fechamento de qualidade (PBI-45):** execução de testes automatizados, auditoria de acessibilidade via axe-core e medições do Google Lighthouse.

3.3.3 Práticas de Engenharia e Controle Colaborativo

O trabalho colaborativo pautou-se pelas seguintes práticas:

a) **rastreabilidade por PBIs:** toda funcionalidade correspondeu a um item do *backlog* do produto formalizado na pasta docs/features/PBI-*.md, contendo seus contratos de interface, dependências e critérios de aceite;

b) **segregação de *branches* e revisão por pares (*peer review*):** cada integrante trabalhou em *branches* temáticas. A aprovação de solicitações de integração (*Pull Requests*) exigiu a revisão de código por outro integrante da equipe. Bacchelli e Bird (2013) mostram que, embora a busca por defeitos seja a principal motivação das revisões, elas também promovem transferência de conhecimento, consciência da equipe sobre o código e soluções alternativas, benefícios relevantes em uma equipe de cinco integrantes;

c) **portões de qualidade na esteira de CI (GitHub Actions):** o repositório foi configurado para validar a cada PR a checagem de tipos (npm run typecheck), a conformidade do *linter* (npm run lint), a formatação (npm run format:check), os testes unitários (npm test), os testes de integração com PostgreSQL real (npm run test:integration), o *build* de produção e os testes de ponta a ponta com Playwright (npm run test:e2e). A prática é discutida por Hilton *et al.* (2016), que estudaram o uso, os custos e os benefícios da integração contínua em projetos de código aberto;

d) **desenvolvimento orientado a testes (TDD):** os comportamentos foram especificados por testes escritos antes do código de produção (Beck, 2002).

Em estudo de caso com quatro equipes industriais, Nagappan *et al.* (2008) observaram redução de 40% a 90% na densidade de defeitos antes do lançamento, acompanhada de aumento de 15% a 35% no tempo inicial de desenvolvimento; esses números referem-se àquele estudo e não foram medidos neste trabalho.

3.4 Registro e Justificativa da Mudança de Escopo (TCC 1 para TCC 2)

Esta seção registra a evolução técnica entre a proposta do projeto (TCC 1) e a implementação final (TCC 2).

A Engenharia de Software preconiza que o refinamento de escopo é parte natural do ciclo de vida de projetos de software, permitindo que a equipe priorize a estabilidade, a segurança e a integridade de dados frente às restrições temporais de entrega.

O Quadro 3.1 detalha as alterações estruturais deliberadas e seus fundamentos técnicos.

Quadro 3.1 — Matriz Justificada de Mudança de Escopo entre TCC 1 e TCC 2

Componente / Funcionalidade	**Planejado no TCC 1**	**Executado no TCC 2 (Versão 2.2)**	**Justificativa Técnica da Mudança**
Stack de Linguagem e *Framework*	React (*Front-end*) + Laravel / PHP (*Back-end*)	Next.js 16 (App Router) + TypeScript *Full-Stack*	A unificação da *stack* em TypeScript em todas as camadas elimina a duplicidade de interfaces entre duas linguagens distintas. O TypeScript compartilha modelos de dados e esquemas Zod nativamente entre cliente e servidor, acelerando o ciclo de desenvolvimento e prevenindo inconsistências em tempo de execução.
Banco de Dados Relacional	MySQL	PostgreSQL 17	O PostgreSQL fornece suporte nativo a restrições de exclusão temporal via índices GiST (EXCLUDE USING GIST), impedindo sobreposição de agendamentos no próprio motor do banco, além de suporte robusto a campos JSONB indexáveis para *snapshots* imutáveis de pedidos.
Visualizador 3D Interativo	Modelos 3D de obras via Three.js / React Three Fiber	Ficha detalhada com fotografias em alta resolução (WebP)	O acervo do Kolô é composto prioritariamente por pinturas, gravuras e técnicas mistas. Fotografias em alta resolução transmitem com fidelidade as texturas e cores reais das peças. A renderização tridimensional

Componente / Funcionalidade	Planejado no TCC 1	Executado no TCC 2 (Versão 2.2)	Justificativa Técnica da Mudança
			aumentava o tempo de carregamento em redes móveis (métrica *Largest Contentful Paint*, LCP). Funcionalidade postergada para trabalhos futuros, focando em esculturas.
Integração com Google Calendar	Sincronização automatizada bidirecional via API Google	Agenda interna manual na plataforma + direcionamento WhatsApp	A sincronização direta via API exigiria processos adicionais de homologação de autorizações institucionais OAuth e acesso a calendários pessoais dos tatuadores. Ademais, cada sessão de tatuagem exige alinhamento prévio de ideias e referências anatômicas, tornando o contato direto via WhatsApp mais adequado à rotina do estúdio.
E-mails Transacionais Contínuos	Disparo de e-mails em cada transição de pedido e agendamento	E-mail restrito à recuperação de senhas; pedidos acompanhados no painel	O estúdio estabeleceu como diretriz operacional a comunicação direta via WhatsApp para tratativas imediatas com clientes. O acompanhamento de pedidos foi centralizado no painel da conta do cliente (Meus Pedidos), evitando sobrecarga com serviços externos de mensageria.
Modelo de Atendimento e Entrega	Foco restrito a vendas e agendamentos presenciais	Modelo integrado: *e-commerce* com retirada no ateliê ou entrega postal, e triagem de agendamentos	O Kolô manteve seu espaço físico em Pinheiros para atendimento e produção artística, incorporando a plataforma *web* como canal assíncrono oficial de vendas e triagem de agendamentos.
Painel de Indicadores e Relatório de Vendas	Adiado na versão 2.2	Incluído em 18/10/2026 (RF32, PBI-48): painel de indicadores no /admin e relatório de vendas por período	Necessidade gerencial de acompanhar faturamento, pedidos e agenda em uma única tela, sem planilhas externas. Por ser somente leitura, não exigiu novas tabelas nem dependências.

Fonte: Elaborado pelos autores (2026).

3.5 Ambiente, Instrumentos e Uso de Ferramentas de Inteligência Artificial

O ecossistema computacional utilizado durante o desenvolvimento abrangeu:

a) **linguagens e *runtimes*:** Node.js versão 24 LTS, TypeScript versão 5.9 em modo estrito, SQL padrão ANSI / PostgreSQL;

b) **ambiente de orquestração:** Docker Engine e Docker Compose executando o banco relacional PostgreSQL 17; a aplicação Next.js é

executada pelo processo Node.js. O Compose versionado contém somente o banco, e a conteinerização da aplicação permanece prevista no PBI-46;

c) **ferramental de desenvolvimento e depuração:** editores Visual Studio Code e Cursor IDE, cliente de banco de dados Beekeeper Studio e terminal de comandos;

d) **ferramentas de testes e qualidade de código:** Vitest, React Testing Library, Playwright, axe-core, ESLint e Prettier;

e) **transparência no uso de assistentes de inteligência artificial:** em conformidade com as diretrizes contemporâneas de integridade acadêmica, registra-se que a equipe utilizou ferramentas de inteligência artificial (IA) generativa (Cursor, Claude Code e Google Antigravity). A atuação desses modelos restringiu-se ao apoio na codificação (*pair programming*): geração de código boilerplate, apoio na elaboração de testes automatizados para regras declaradas e identificação de inconsistências de tipagem. Toda a tomada de decisão arquitetural, a modelagem conceitual do banco de dados, a definição de requisitos e a validação do software foram concebidas, supervisionadas e homologadas criticamente pelos acadêmicos integrantes do grupo.

3.6 Critérios de Validação e Homologação do Sistema

Para atestar o funcionamento da implementação e subsidiar a discussão de resultados, o projeto adotou critérios objetivos de validação técnica:

a) **critério 1 (cobertura funcional):** mapeamento e aprovação de 100% dos requisitos funcionais categorizados como prioridade P0 na suíte de testes automatizados;

b) **critério 2 (isolamento de concorrência):** comprovação prática de que reservas concorrentes da mesma obra de arte física unitária não resultam em venda duplicada (*overselling*);

c) **critério 3 (desempenho e carregamento):** atingimento de índice igual ou superior a 90 pontos no Google Lighthouse com tempo de LCP inferior a 2,5 segundos sob emulação de rede móvel (RNF13);

d) **critério 4 (acessibilidade digital):** zero inconformidades críticas ou sérias reportadas pelo motor axe-core segundo o padrão internacional WCAG 2.1 nível AA (RNF21);

e) **critério 5 (aceite do usuário):** condução de sessão assistida de homologação com a administradora e tatuadora do Kolô Ateliê & Estúdio, coletando retorno qualitativo sobre a operação do sistema e os fluxos implementados.

4 DESENVOLVIMENTO DO SISTEMA

4.1 Levantamento e Especificação de Requisitos

O desenvolvimento do sistema Kolô fundamentou-se nas necessidades operacionais diagnosticadas no ateliê e estúdio de tatuagem em Pinheiros, unificando a vitrine de obras de arte, o módulo de comércio eletrônico assíncrono e o assistente em etapas de triagem de tatuagens.

Conforme preconizado por Pressman e Maxim (2021), a engenharia de requisitos estabelece as bases de comunicação, restrições e critérios de aceitação essenciais à estabilidade do ciclo de vida do software. Para o escopo final da aplicação (versão 2.2), os requisitos foram categorizados em funcionais (RF), não funcionais (RNF) e regras de negócio (RN), priorizados em P0 (indispensável à defesa e operação central) e P1 (incrementos integrados).

4.1.1 Requisitos Funcionais

Os requisitos funcionais determinam as operações, serviços e transformações de estado que a aplicação fornece aos seus respectivos atores: Visitante, Cliente, Artista e Administrador. O Quadro 4.1 detalha a especificação de RF01 a RF32, distribuídos por módulos de domínio.

Quadro 4.1 — Requisitos Funcionais do Sistema Kolô (RF01 a RF32)

ID	Módulo de Domínio	Descrição do Requisito Funcional	Prioridade
RF01	Autenticação	Permitir o cadastro autônomo de clientes mediante fornecimento de nome completo, e-mail único, telefone e senha de acesso.	P0
RF02	Autenticação	Realizar autenticação de usuários por credenciais (e-mail e senha), mantendo a sessão persistida no banco de dados com capacidade de revogação explícita.	P0
RF03	Autenticação	Disponibilizar recuperação de senha de acesso via correio eletrônico, gerando *token* criptográfico com uso único e prazo de expiração determinado.	P0
RF04	Perfil do Usuário	Permitir a atualização dos dados cadastrais do cliente, incluindo alteração de nome, telefone de contato e redefinição de senha autenticada.	P0
RF05	Perfil do Usuário	Permitir o cadastro e edição de um endereço de entrega padronizado por cliente, utilizado para conferência e despacho de pedidos no *checkout*.	P0

ID	Módulo de Domínio	Descrição do Requisito Funcional	Prioridade
RF06	Controle de Acesso	Implementar controle de acesso baseado em papéis (RBAC), segregando autorizações entre os perfis CLIENTE, ARTISTA e ADMIN.	P0
RF07	Vitrine	Apresentar página inicial (Home) responsiva destacando obras em evidência, manifesto do ateliê e chamada para o assistente de agendamento.	P0
RF08	Institucional	Exibir páginas institucionais contendo políticas de privacidade de dados, termos de uso da plataforma e normas de cancelamento e reembolso.	P0
RF09	Catálogo	Exibir catálogo de obras de arte em grade bidimensional responsiva, com paginação de registros e filtros de ordenação por data, preço e destaque.	P0
RF10	Catálogo	Disponibilizar ficha detalhada da obra, apresentando galeria de imagens otimizadas, ficha técnica (dimensões, técnica, ano) e estado de disponibilidade.	P0
RF11	*E-commerce*	Manter carrinho de compras persistente, armazenando itens em *cookie* seguro para visitantes anônimos e sincronizando com o banco após autenticação.	P0
RF12	*E-commerce*	Estruturar processo de *checkout* com conferência de itens e seleção entre retirada no ateliê ou entrega postal com cálculo de frete no servidor.	P0
RF13	*E-commerce*	Processar transações financeiras integradas ao *gateway* Mercado Pago (Checkout Pro), abrangendo pagamentos via Pix, cartão e boleto sem trafegar dados de cartão pelo servidor.	P0
RF14	*E-commerce*	Confirmar automaticamente o status do pedido para “Pago” e realizar a baixa definitiva de estoque mediante recebimento de *webhook* assinado e idempotente.	P0
RF15	*E-commerce*	Efetuar reserva temporária das unidades de obras durante o *checkout* por período fixo de 10 minutos, liberando-as em caso de desistência ou expiração.	P0
RF16	*E-commerce*	Disponibilizar ao cliente painel de acompanhamento de pedidos realizados, histórico de transações, linha do tempo de status e código de rastreamento postal.	P0
RF17	Portfólio *Tattoo*	Apresentar galeria de trabalhos de tatuagem realizados pelos artistas residentes, categorizados por profissional, estilo artístico e região anatômica.	P0
RF18	Portfólio *Tattoo*	Disponibilizar mecanismo de busca textual no portfólio de tatuagens por palavras-chave e estilo artístico.	P0
RF19	Portfólio *Tattoo*	Disponibilizar módulo de gestão de portfólio para administradores e artistas, permitindo inclusão, edição, reordenação e exclusão de fotos de seus trabalhos.	P0
RF20	Agendamento	Disponibilizar assistente público em etapas: coleta de nome, seleção de artista, estilo, região anatômica, porte e janela de preferência.	P0
RF21	Agendamento	Gerar *link* de direcionamento para o WhatsApp (wa.me) ao término do assistente de agendamento, com mensagem estruturada contendo dados e aceites declarados.	P0
RF22	Agendamento	Permitir o cadastro manual de sessões na agenda interna pelo artista ou administrador, definindo cliente, profissional, horário de início e fim.	P0

ID	Módulo de Domínio	Descrição do Requisito Funcional	Prioridade
RF23	Conformidade	Exigir confirmação explícita de alerta informando que a ficha de anamnese clínica deve ser respondida presencialmente antes do procedimento de tatuagem.	P0
RF24	Conformidade	Exigir confirmação obrigatória de termo de consentimento livre e esclarecido a ser assinado fisicamente na data da sessão no ateliê.	P0
RF25	Conformidade	Exigir declaração obrigatória de maioridade civil (idade igual ou superior a 18 anos) para liberação do redirecionamento ao canal de agendamento.	P0
RF26	*Back-office*	Disponibilizar CRUD completo de obras de arte com suporte a múltiplas fotografias, dados catalográficos, preço em centavos, estoque e publicação.	P0
RF27	*Back-office*	Fornecer *upload* de imagens com validação de tipo MIME e extensão, além de geração automatizada de miniaturas.	P0
RF28	*Back-office*	Disponibilizar gerenciamento de artistas residentes, estilos de tatuagem vinculados e *tags* temáticas de obras.	P0
RF29	*Back-office*	Prover painel administrativo de pedidos com filtros de status, vinculação de código de rastreio postal e gestão de estornos financeiros manuais.	P0
RF30	*Back-office*	Disponibilizar visualização consolidada de clientes cadastrados, com histórico de compras realizadas e sinalização de contas com anonimização solicitada.	P1
RF31	*Back-office*	Permitir a parametrização de configurações do estabelecimento, incluindo canais de contato, horários de atendimento e textos institucionais.	P1
RF32	*Back-office*	Prover painel de indicadores (faturamento, pedidos e obras por situação, horários dos próximos 7 dias) e relatório de vendas por período, com obras mais vendidas, faturamento por artista e versão para impressão.	P0

Fonte: Elaborado pelos autores (2026).

4.1.2 Requisitos Não Funcionais

Os requisitos não funcionais definem os critérios de qualidade técnica, segurança, desempenho e manutenibilidade observados na concepção do software. O Quadro 4.2 sintetiza os requisitos não funcionais, distinguindo o que está implementado na aplicação e o que está projetado para a infraestrutura de produção (PBI-46).

Quadro 4.2 — Requisitos Não Funcionais do Sistema Kolô (RNF01 a RNF24)

Categoria	ID	Especificação do Requisito Não Funcional	Situação / Mecanismo de Verificação
Segurança	RNF01	Todo o tráfego deve ocorrer sob protocolo criptográfico HTTPS com certificados válidos.	Projetado para produção com Caddy (PBI-46).

Categoria	ID	Especificação do Requisito Não Funcional	Situação / Mecanismo de Verificação
Segurança	RNF02	*Runtimes*, *frameworks* e dependências devem manter versões ativas e isentas de vulnerabilidades conhecidas.	Auditoria pontual registrada no fechamento do PBI-45, sem vulnerabilidades altas/críticas naquela medição; não há etapa npm audit no *workflow* de CI.
Segurança	RNF03	Senhas de usuários armazenadas sob funções de *hash* lento scrypt com *salt* individual (Better Auth).	Implementado; verificação de modelo e banco.
Segurança	RNF04	Prevenção contra Injeção de SQL (SQLi) mediante parametrização integral de consultas via Prisma ORM.	Implementado; consultas parametrizadas na aplicação.
Segurança	RNF05	Prevenção contra *Cross-Site Scripting* (XSS) via escape automático de *templates* e Content-Security-Policy (CSP).	Implementado na aplicação via src/proxy.ts.
Segurança	RNF06	Proteção contra CSRF em todas as ações mutativas (Server Actions) associada a *cookies* HttpOnly, Secure e SameSite=Lax.	Implementado na camada de aplicação.
Segurança	RNF07	Emissão de cabeçalhos de segurança HTTP: HSTS, X-Content-Type-Options e Referrer-Policy.	Implementado em src/lib/seguranca.ts e aplicado por src/proxy.ts às rotas abrangidas pelo matcher; HSTS somente em produção. HTTPS público permanece previsto no PBI-46.
Segurança	RNF08	Mitigação de abusos via *rate limiting* em *login*, recuperação de senha e formulários públicos.	Implementado na aplicação via tabela rate_limit.
Segurança	RNF09	Validação de toda entrada no servidor por esquemas declarativos com tipagem estrita (Zod).	Implementado em todos os módulos.
Segurança	RNF10	Nenhum dado de cartão de crédito trafega ou é persistido no servidor da aplicação.	Implementado via Checkout Pro hospedado.
Segurança	RNF11	*Webhooks* de confirmação de pagamento com validação de assinatura e processamento idempotente.	Implementado via WebhookSignatureValidator.
Segurança	RNF12	Chaves de API e segredos exclusivamente em variáveis de ambiente, nunca commitados.	Implementado; verificação no repositório.
Desempenho	RNF13	Páginas públicas de catálogo e exibição de obras com LCP abaixo de 2,5 segundos em rede móvel 4G simulada.	Implementado; 2,43 s no catálogo e 2,25 s na obra.
Desempenho	RNF14	Imagens servidas em formato moderno e comprimido (WebP), com renderização responsiva e carregamento diferido.	Implementado via Next.js Image e Sharp.
Disponibilidade	RNF15	Ambiente conteinerizado com política de reinicialização automática (restart: unless-stopped).	Projetado no docker-compose de produção (PBI-46).

Categoria	ID	Especificação do Requisito Não Funcional	Situação / Mecanismo de Verificação
Disponibilidade	RNF16	Rotina automatizada de *backup* diário do banco de dados relacional com retenção mínima de 7 dias.	Projetado na rotina de produção (PBI-46).
Privacidade	RNF17	Princípio de minimização de coleta de dados pessoais (LGPD), coletando apenas dados necessários à compra e entrega.	Implementado nos esquemas cadastrais.
Privacidade	RNF18	O banco de dados não persiste histórico clínico, prontuários de anamnese ou dados sensíveis de saúde de tatuagem.	Implementado no fluxo do assistente.
Privacidade	RNF19	Encerramento da conta pelo titular com anonimização cadastral, preservando os registros contábeis.	Implementado na ação excluirPropriaConta.
Usabilidade	RNF20	Responsividade adaptável de 320 px a 1920 px sem rolagem horizontal indesejada e alvos de toque de 48 px.	Implementado e validado em testes de ponta a ponta (E2E).
Usabilidade	RNF21	Acessibilidade digital segundo WCAG 2.1 nível AA: navegação por teclado, foco visível e atributos alt.	Verificação parcial: varredura axe-core sem violações críticas ou sérias nos critérios avaliados; navegação por teclado e foco visível ainda pendentes de verificação.
Manutenção	RNF22	Tipagem estática estrita em TypeScript, *linting* obrigatório e formatação automática validados em CI.	Implementado no GitHub Actions.
Manutenção	RNF23	Ambiente de desenvolvimento local reprodutível por arquivos declarativos de contêineres Docker.	Implementado via docker-compose.yml.
Manutenção	RNF24	Registro de logs e captura de exceções em ambiente produtivo.	Projetado para integração Sentry/Pino (PBI-46).

Fonte: Elaborado pelos autores (2026).

4.1.3 Regras de Negócio do Domínio

As regras de negócio do Kolô definem as restrições de integridade, contabilidade e segurança do domínio:

a) **RN01 — acesso público versus autenticado:** a exploração da vitrine, catálogo de obras, visualização da ficha técnica, galeria do portfólio de tatuagens e o preenchimento do assistente de agendamento são abertos ao público. A finalização do *checkout* de compras e a gestão de dados cadastrais exigem autenticação de usuário. O assistente de agendamento não efetua gravação de registro na tabela de agendamentos;

b) **RN02 — unicidade e estoque de obras de arte:** as obras de arte produzidas no ateliê possuem estoque inicial padrão unitário (1), podendo ser expandido pelo administrador no caso de tiragens numeradas. O sistema não autoriza a comercialização de quantidade que ultrapasse o estoque disponível;

c) **RN03 — reserva temporária no *checkout*:** ao iniciar a fase de pagamento no *checkout*, as unidades selecionadas são bloqueadas em favor da sessão do comprador por uma janela de exatamente dez minutos. Expirado esse período sem quitação, as unidades retornam automaticamente ao acervo disponível;

d) **RN04 — concorrência transacional de estoque:** o processo de reserva e baixa de estoque é protegido por transações ACID com bloqueio pessimista (SELECT ... FOR UPDATE), assegurando que requisições paralelas para uma mesma obra com estoque unitário não gerem venda duplicada (*overselling*);

e) **RN05 — quitação vinculada à confirmação do *gateway*:** a confirmação de pagamento do pedido (PAGO) depende da aprovação consultada na API do Mercado Pago após o recebimento de *webhook* autenticado. A baixa de estoque ocorre na mesma transação quando há unidades disponíveis; aprovações sem estoque são sinalizadas para estorno, conforme a Seção 4.4.2;

f) **RN06 — manutenção de reserva para meios assíncronos:** pagamentos iniciados via Pix ou boleto bancário resultam em pedidos com status pendente; caso o pagamento seja gerado dentro dos dez minutos de reserva, a expiração das unidades é prorrogada no *webhook* até a data-limite de vencimento do meio;

g) **RN07 — aritmética monetária inteira:** todos os valores financeiros são manipulados e persistidos em centavos (números inteiros), prevenindo imprecisões decorrentes de arredondamentos de ponto flutuante;

h) **RN08 — impossibilidade de sobreposição de agendas:** um mesmo tatuador residente não pode ter dois agendamentos confirmados com

sobreposição temporal no mesmo intervalo de horas, restrição imposta no banco de dados por meio de exclusão relacional via tipos de alcance temporal (btree_gist);

i) **RN09 — normalização temporal em UTC:** todos os carimbos de data e hora são armazenados no banco de dados em UTC (timestamptz), com exibição e cálculos de interface convertidos para o fuso horário oficial America/Sao_Paulo;

j) **RN10 — segregação de escopo por artista:** usuários com o perfil ARTISTA possuem permissão restrita para manipular o seu respectivo portfólio, sua disponibilidade de agenda e os agendamentos dos quais são responsáveis;

k) **RN11 — transição automática de status de obra:** quando o estoque de uma obra ativa atinge o total de zero unidades, seu estado de publicação é transicionado automaticamente de “Disponível” para “Esgotada”, mantendo a peça no acervo histórico, porém desabilitando adições ao carrinho;

l) **RN12 — anonimização de dados em exclusão de conta:** quando um cliente solicita o encerramento de sua conta de acesso, em observância aos artigos 16 e 18 da LGPD, suas credenciais de acesso, sessões, endereço e dados de qualificação pessoal são removidos ou anonimizados, e o endereço dos pedidos é reduzido a cidade e UF; os registros fiscais e os pedidos são preservados para fins contábeis e de prestação de contas. A exclusão é recusada enquanto houver pedido pago em andamento (pago, em processamento ou enviado).

4.2 Arquitetura de Software e Tecnologias Adotadas

A plataforma Kolô foi estruturada segundo o padrão arquitetural de monólito modular cliente-servidor, com a aplicação executada em Node.js e o banco PostgreSQL em contêiner Docker no ambiente local.

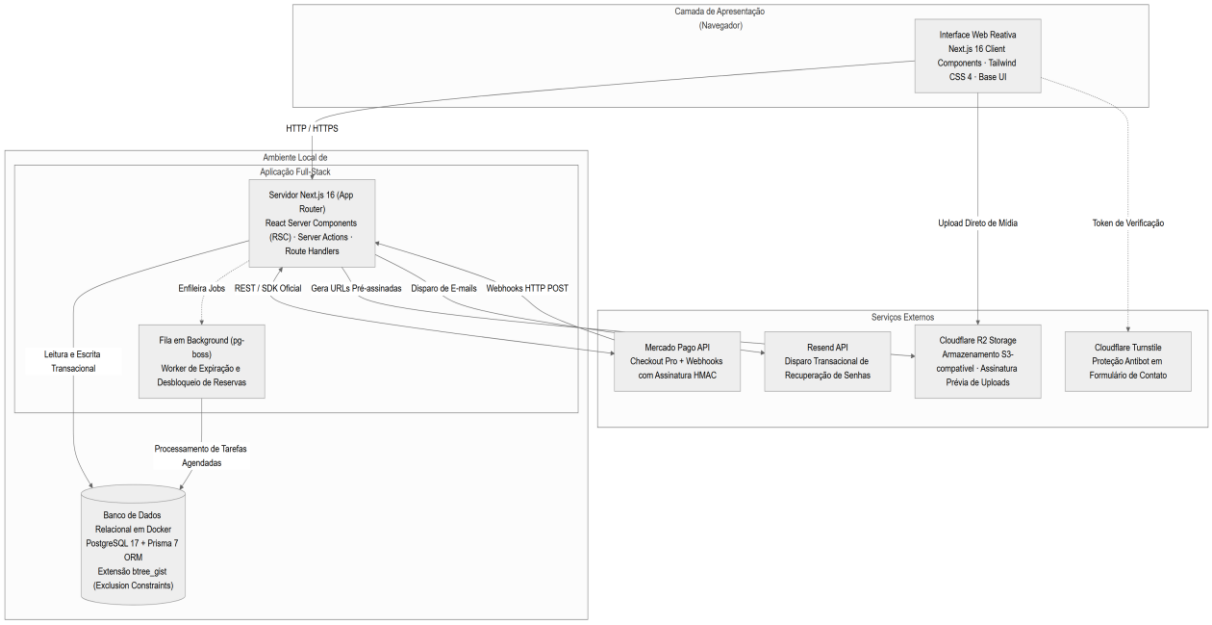
A escolha do monólito modular fundamenta-se nas lições de Sommerville (2019) e Richards e Ford (2020), e na caracterização de Al-Qora'n e Al-Said Ahmad (2025) discutida na Seção 2.7. Esses autores ressaltam que sistemas integrados de

médio porte obtêm coesão, menor custo operacional e menor complexidade de infraestrutura ao manter módulos de negócio delimitados dentro de um mesmo processo executável, evitando os custos de serialização de rede e orquestração inerentes aos microsserviços distribuídos.

4.2.1 Diagrama Estrutural da Arquitetura

A Figura 4.1 ilustra a disposição dos componentes que compõem o ecossistema da aplicação, distinguindo as camadas de apresentação, núcleo de aplicação, persistência e integrações externas.

Figura 4.1 — Diagrama de Arquitetura da Aplicação Kolô



Fonte: Elaborado pelos autores (2026).

4.2.2 Justificativa da *Stack* Tecnológica

Cada tecnologia do sistema foi selecionada com base em critérios técnicos mensuráveis:

a) **TypeScript (linguagem):** adotado tanto no *back-end* quanto no *front-end* em modo estrito (strict: true). Garante integridade de tipos de ponta a ponta, permitindo que alterações nos modelos de dados ou esquemas de validação reflitam imediatamente em avisos de compilação;

b) **Next.js 16 e Node.js 24 LTS (*framework full-stack* e *runtime*):** a adoção do Next.js App Router consolida a arquitetura monolítica modular. Por meio dos *React Server Components* (RSC), o servidor renderiza a vitrine de obras e portfólios diretamente em HTML, reduzindo o volume de JavaScript enviado ao navegador (React, 2024; Vercel, 2026). As alterações de estado ocorrem via *Server Actions*, que encapsulam validações com proteção CSRF embutida;

c) **Tailwind CSS 4 e shadcn/ui (estilização e componentes):** a interface utiliza componentes desacoplados baseados nas primitivas acessíveis do Base UI (@base-ui/react) estilizadas pelo Tailwind CSS, assegurando conformidade com os *tokens* de identidade visual do ateliê e semântica de acessibilidade (ARIA) nativa;

d) **PostgreSQL 17 e Prisma 7 (persistência e ORM):** o PostgreSQL foi selecionado devido ao seu suporte nativo a índices GiST para verificação de sobreposição temporal de intervalos, isolamento serializável de transações e campos do tipo JSONB para armazenamento de *snapshots* de endereços e *payloads* de *webhooks* (PostgreSQL Global Development Group, 2026). O Prisma 7 atua como camada de mapeamento objeto-relacional (ORM), oferecendo migrações declarativas e consultas parametrizadas;

e) **Better Auth (autenticação e sessões):** adotado para emissão de sessões registradas e verificadas no banco de dados relacional com senhas derivadas em scrypt. Permite a revogação de sessões ativas (*logout* forçado, encerramento de acesso pós-exclusão LGPD);

f) **Mercado Pago Checkout Pro (*gateway* de pagamento):** a solução de Checkout Pro transfere a responsabilidade da coleta de números de cartões para o ambiente seguro do provedor, enquadrando o Kolô no nível simplificado de conformidade PCI DSS (SAQ-A) e oferecendo suporte simultâneo a Pix, cartão de crédito e boleto bancário (Mercado Pago, 2024);

g) **Cloudflare R2 (armazenamento de objetos):** solução de armazenamento compatível com a API S3 da AWS, sem tarifas de tráfego de saída (*egress fees*), viabilizando o armazenamento de imagens do acervo;

h) **pg-boss (fila em *background*):** gerenciador de filas executado no próprio PostgreSQL, empregado para o agendamento de tarefas de liberação de reservas expiradas.

4.2.3 Organização Modular do Código-Fonte

A arquitetura do projeto organiza-se por módulos de domínio no diretório src/modules/, conforme detalhado no Quadro 4.3. Cada módulo expõe suas operações públicas por meio de um arquivo index.ts, evitando acoplamento indevido com suas funções internas.

Quadro 4.3 — Estrutura de Módulos de Domínio da Aplicação (src/modules/)

Módulo	**Responsabilidade Central**	**Dependências Principais**
artists	Gerenciamento de artistas residentes, perfis e vínculos com estilos.	Prisma
catalog	Vitrine de obras, catálogo paginado, filtros de ordenação e ficha detalhada.	Prisma, media
contact	Formulário público de contato institucional com proteção Turnstile.	Prisma, Cloudflare Turnstile
customers	Consulta administrativa de clientes, histórico de compras e perfil consolidado.	Prisma, orders
endereco	Validação de CEP, formatação de endereço de entrega e cálculo de frete.	Prisma
identity	Autenticação, controle de papéis (RBAC), sessões e recuperação de senha.	Better Auth, Prisma, Resend
media	Validação de *uploads*, geração de assinaturas prévias para o R2 e *thumbnails*.	AWS S3 SDK, Sharp
orders	*Checkout*, reserva transacional de estoque, despacho postal e ciclo de pedidos.	Prisma, payments, pg-boss
payments	Integração com Mercado Pago, cálculo de assinatura HMAC e *webhooks*.	Prisma, Mercado Pago SDK
portfolio	Gestão de trabalhos de tatuagem realizados, ordenação e vinculação de estilos.	Prisma, media
reports	Painel de indicadores e relatório de vendas por período (somente leitura), restritos ao administrador.	Prisma, orders, catalog, scheduling
scheduling	Agenda de horários dos artistas residentes com bloqueio de sobreposição GiST.	Prisma
settings	Parametrização institucional do ateliê, canais de contato e horários.	Prisma

Fonte: Elaborado pelos autores (2026).

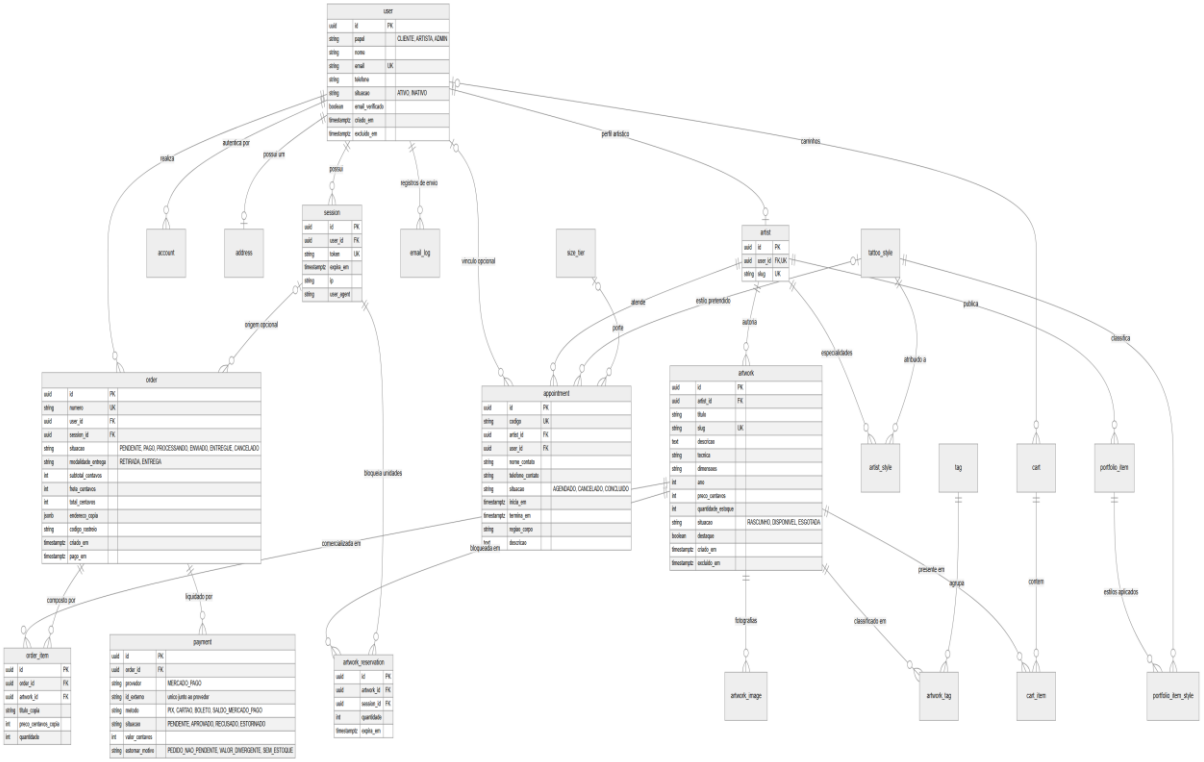
4.3 Modelagem de Dados

O modelo de dados do Kolô foi normalizado na 3ª Forma Normal (3FN), garantindo integridade referencial, atomicidade nas operações e preservação histórica de transações comerciais.

4.3.1 Diagrama Entidade-Relacionamento (DER)

A Figura 4.2 apresenta o Diagrama Entidade-Relacionamento detalhando as principais tabelas, chaves primárias, relacionamentos de cardinalidade e chaves estrangeiras. O diagrama apresenta um recorte do modelo lógico com entidades, cardinalidades e atributos selecionados; não reproduz todas as colunas do banco. As obras relacionam-se aos pedidos por meio de order_item. Os vínculos opcionais com sessão, cliente, estilo e porte são indicados pelas cardinalidades; a unicidade do pagamento combina provedor e identificador externo. O modelo físico é detalhado na Seção 4.3.2 e no esquema Prisma.

Figura 4.2 — Modelo Entidade-Relacionamento do Banco de Dados Relacional (DER)



Fonte: Elaborado pelos autores (2026).

4.3.2 Dicionário de Dados e Modelo Físico

O modelo físico implementado no PostgreSQL incorpora decisões voltadas à integridade histórica de dados:

a) ***snapshots* imutáveis de pedidos (order.endereco_copia e order_item):** para evitar inconsistências decorrentes de alterações cadastrais posteriores à compra, order armazena um *snapshot* no campo endereco_copia (estrutura JSONB) no momento do fechamento, e order_item congela o título da obra e o valor unitário (preco_centavos_copia);

b) **separação de chaves de mídia:** o banco armazena a chave relativa do objeto dentro do *bucket* R2 (por exemplo, obras/artistId/uuid.webp), em vez de URLs absolutas. A resolução da URL pública e a localização da miniatura associada são derivadas pelo módulo media, facilitando eventuais migrações de provedor de mídia;

c) **restrição física de exclusão temporal na agenda:** em atendimento à regra RN08, a tabela appointment possui uma restrição de exclusão DDL no PostgreSQL via extensão btree_gist:

```
ALTER TABLE "appointment"
  ADD CONSTRAINT "appointment_no_overlap"
  EXCLUDE USING gist (
    "artist_id" WITH =,
    tstzrange("inicia_em", "termina_em", '[)') WITH &&
  )
  WHERE ("excluido_em" IS NULL AND "situacao" <> 'CANCELADO');
```

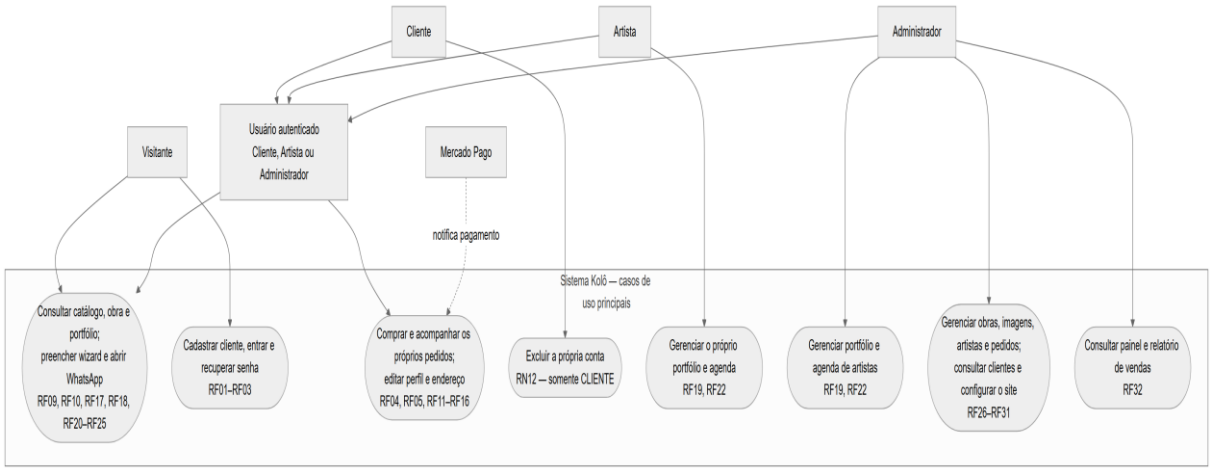
Essa restrição assegura que duas transações simultâneas não consigam inserir intervalos concorrentes para o mesmo profissional; agendamentos cancelados ou excluídos logicamente não participam da verificação.

4.3.3 Casos de Uso e Classes do Domínio

A Figura 4.3 apresenta o diagrama de casos de uso, que relaciona os atores — Visitante, Cliente, Artista e Administrador — às funcionalidades do sistema e aos requisitos que as originam. O esquema agrupa as operações comuns aos usuários autenticados, sem pressupor herança integral de permissões: Cliente, Artista e Administrador podem comprar e acompanhar os próprios pedidos, mas a exclusão da

própria conta pelo site é restrita ao papel CLIENTE. O artista gerencia o próprio portfólio e agenda; o administrador também pode gerenciar esses dados de outros artistas. As associações representam acesso funcional, e não uma hierarquia de papéis. O Mercado Pago figura como ator externo, pois é a origem da confirmação de pagamento.

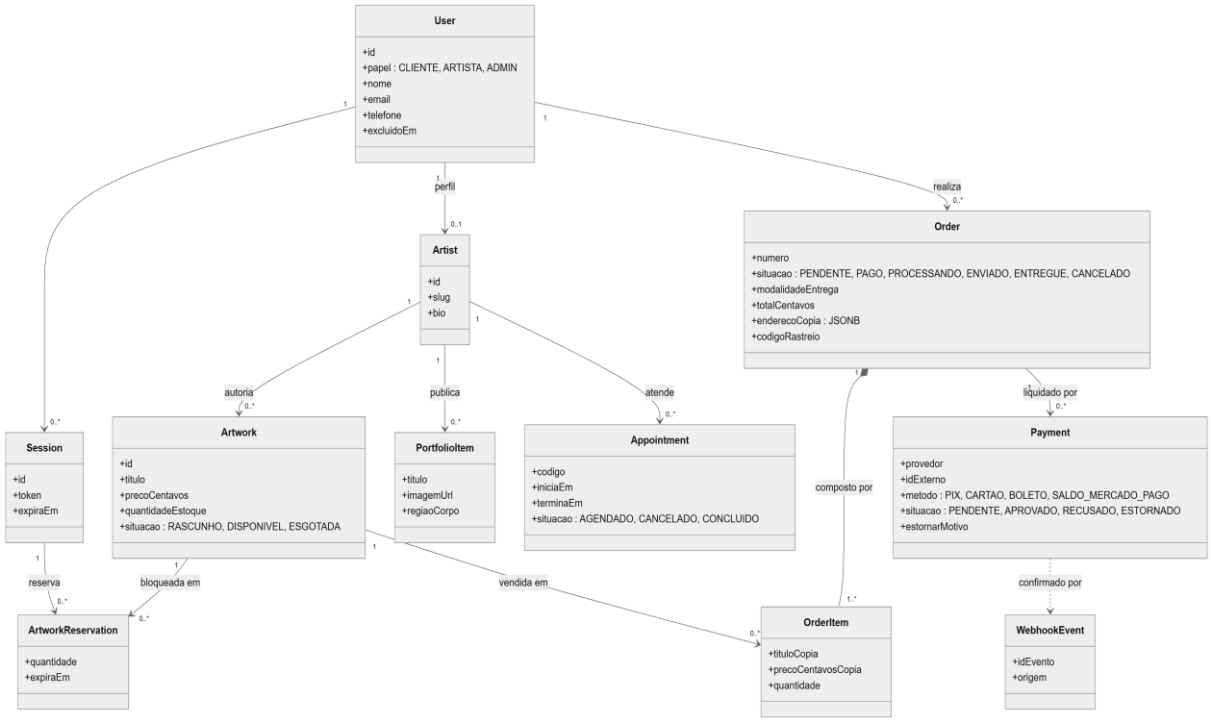
Figura 4.3 — Diagrama de Casos de Uso do Sistema Kolô



Fonte: Elaborado pelos autores (2026).

A Figura 4.4 apresenta o diagrama de classes do domínio, restrito às entidades centrais do negócio: usuário, sessão, artista, obra, reserva, pedido, pagamento, agendamento e portfólio. Os atributos correspondem aos campos do esquema relacional (Seção 4.3.2) e as associações, às cardinalidades da Figura 4.2. Como o sistema é escrito em TypeScript, com acesso a dados por ORM e regras de negócio em funções de cada módulo, as classes representam entidades de dados, e não objetos com comportamento.

Figura 4.4 — Diagrama de Classes do Domínio



Fonte: Elaborado pelos autores (2026), com base no esquema do banco de dados (prisma/schema.prisma).

4.4 Decisões de Implementação e Algoritmos do Sistema

Esta seção aprofunda as principais decisões técnicas e os algoritmos desenvolvidos para garantir a solidez operacional da plataforma.

4.4.1 Controle de Concorrência e Reserva Temporária de Estoque (PBI-25)

Em virtude de o ateliê comercializar peças exclusivas de estoque unitário (Q = 1), a concorrência por compras no *checkout* exige proteção contra *overselling*.

O algoritmo de reserva temporária de dez minutos, implementado na função reservarItens do módulo orders, opera segundo os seguintes passos:

a) **abertura de transação:** o processo é encapsulado em um bloco prisma.$transaction;

b) **bloqueio ordenado de linhas:** para prevenir impasses mútuos (*deadlocks*) entre requisições concorrentes, a consulta com trava pessimista bloqueia as obras sempre na mesma ordem, crescente por identificador:

```
SELECT id FROM artwork WHERE id = ANY($1::uuid[]) ORDER BY id FOR
UPDATE;
```

c) **cálculo de unidades livres:** a quantidade disponível é expressa pela Equação 4.1:

$$E_{livre} = Q_{estoque} - \Sigma R_{ativas} \quad (4.1)$$

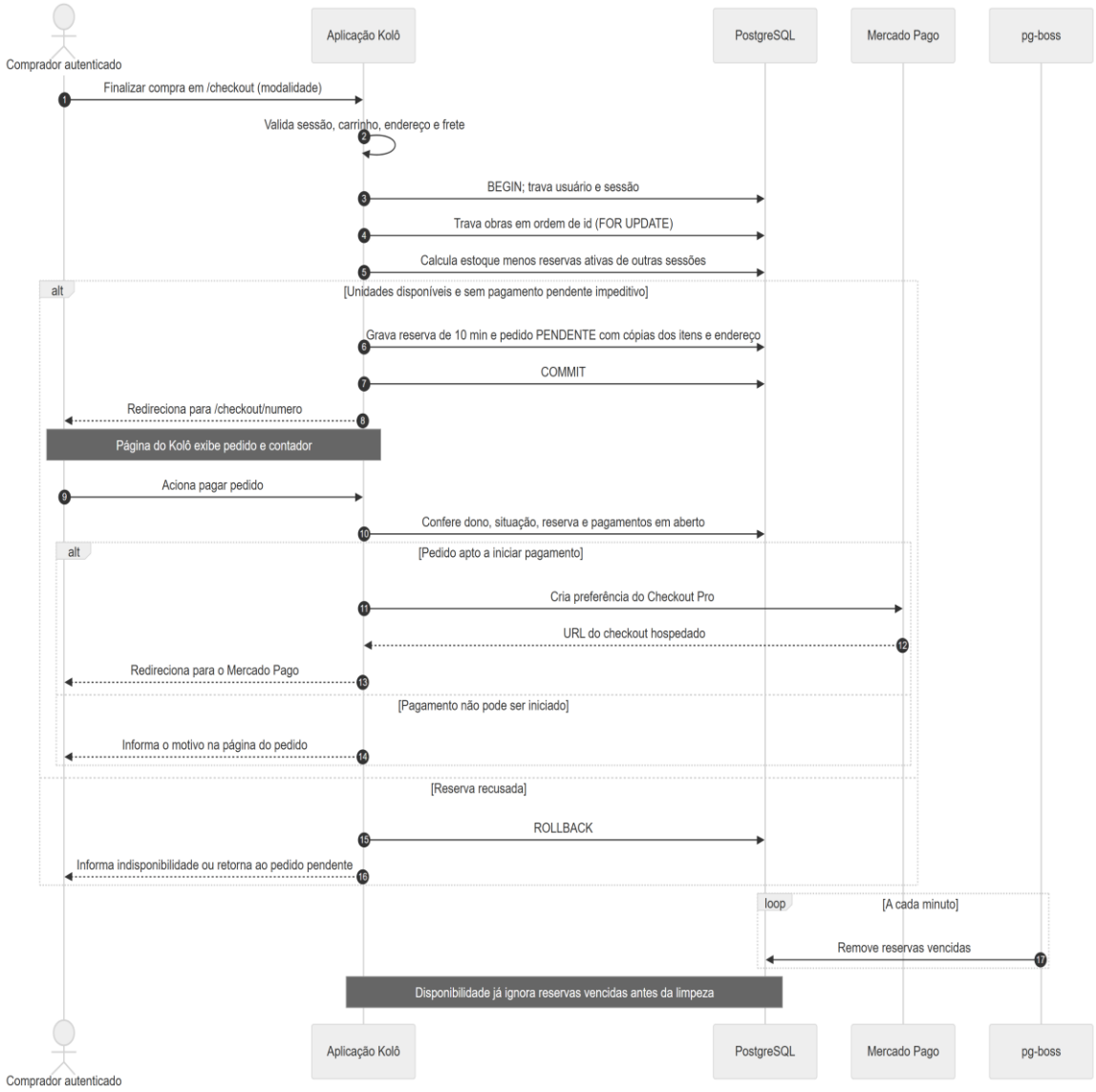
em que R_{ativas} corresponde a todas as reservas ativas (expira_em > agora) de outras sessões (session_id ≠ S_{atual});

d) **reserva atômica (“tudo ou nada”):** se qualquer item solicitado apresentar $E_{livre} < Q_{solicitada}$, a transação rejeita a solicitação e informa os itens indisponíveis;

e) **gravação e expiração:** se todas as unidades estiverem disponíveis, as linhas de reserva são gravadas com expira_em = agora + 10 minutos. O *worker* em segundo plano gerenciado pelo pg-boss monitora a tabela periodicamente a cada 60 segundos (* * * * *) executando a limpeza assíncrona de registros expirados.

A Figura 4.5 detalha a sequência de interações do fluxo de reserva, desde o envio do carrinho até o redirecionamento ao *checkout* hospedado do Mercado Pago.

Figura 4.5 — Diagrama de Sequência da Reserva Temporária de Estoque (RF15)



Fonte: Elaborado pelos autores (2026), com base na função reservarItens (src/modules/orders/reserva.ts).

4.4.2 Processamento Idempotente de *Webhooks* com Assinatura HMAC (PBI-28)

A confirmação de quitação de pedidos depende do processamento assíncrono de notificações enviadas pelo *gateway* Mercado Pago, exigindo autenticação da mensagem e tratamento contra retransmissões de rede (*at-least-once delivery*).

O *endpoint* /api/webhooks/mercadopago opera em três etapas:

a) **validação da assinatura HMAC:** a autenticidade é verificada por meio do WebhookSignatureValidator oficial do SDK do Mercado Pago. O validador extrai o cabeçalho x-signature (que transporta o *timestamp* ts e o *hash* v1),

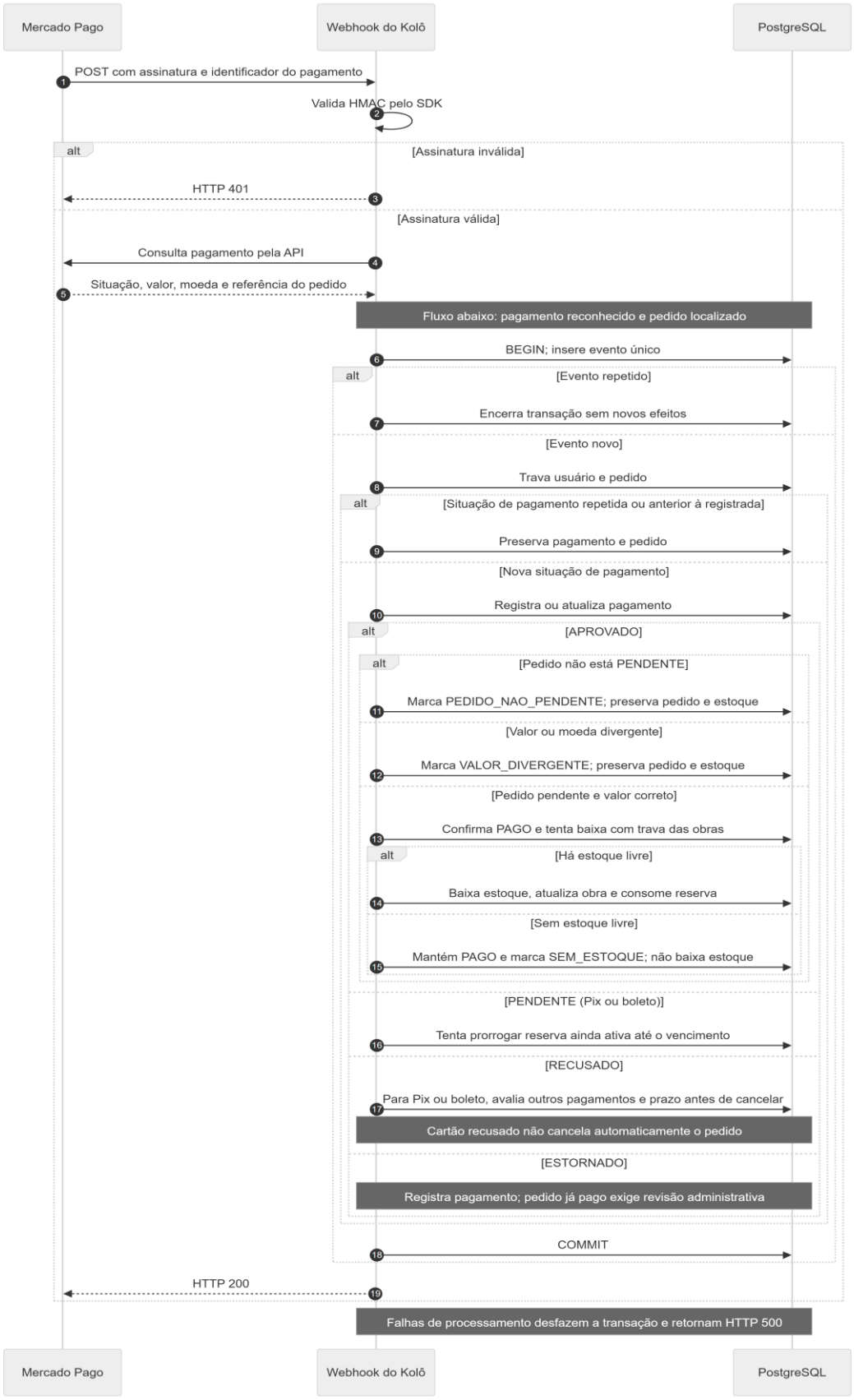
o identificador da requisição x-request-id, o data.id e a chave secreta compartilhada, comparando o *hash* calculado em tempo constante. Requisições inválidas ou defasadas temporalmente são rejeitadas com código HTTP 401;

b) **barreira de idempotência:** a tabela webhook_event armazena os identificadores únicos de eventos recebidos (id_evento). Caso o identificador já exista no banco (violação de unicidade), o sistema reconhece a requisição como notificação repetida e retorna código HTTP 200 imediatamente, sem duplicar ações no pedido;

c) **baixa de estoque transacional:** confirmada a autenticidade e unicidade, uma transação única atualiza o status do pedido para PAGO, registra a transação na tabela payment e aciona baixarEstoque. Esta função decrementa o estoque físico e consome a respectiva reserva. Se o estoque resultante for zero, o status da obra transiciona para ESGOTADA. Se a aprovação chegar para um pedido que não está mais pendente, com valor divergente ou para uma peça já adquirida por outro cliente, o pagamento é marcado com o motivo de estorno (estornar_motivo: PEDIDO_NAO_PENDENTE, VALOR_DIVERGENTE ou SEM_ESTOQUE) e o pedido passa a figurar no filtro “Estorno pendente” do painel (PBI-43), para que o administrador efetue o estorno manual sem gerar inconsistência contábil.

A Figura 4.6 resume a sequência de tratamento de uma notificação: validação da assinatura, consulta do pagamento à API do *gateway*, barreira de idempotência e atualização transacional do pedido e do estoque.

Figura 4.6 — Diagrama de Sequência do Processamento do *Webhook* de Pagamento (RF14)



Fonte: Elaborado pelos autores (2026), com base no tratamento de notificações (src/modules/payments/webhook.ts).

4.4.3 *Upload* de Imagens com URLs Pré-Assinadas (PBI-17)

Para evitar que o tráfego de arquivos pesados de imagem onere o servidor da aplicação, adotou-se o padrão de *upload* com URLs pré-assinadas:

a) o cliente administrativo solicita autorização de envio via Server Action;

b) o servidor valida o tamanho declarado (até 5 MiB, equivalentes a 5 × 1024 × 1024 bytes) e o tipo MIME declarado (image/jpeg, image/png, image/webp); a extensão da chave é derivada desse tipo, sem depender do nome original do arquivo;

c) o servidor aciona o cliente S3 configurado com o Cloudflare R2 e gera uma URL assinada temporária com método PUT e validade de 5 minutos, gerando uma chave aleatória no formato <modulo>/<artistaId>/<uuid>.<extensão>;

d) o navegador envia o binário diretamente do dispositivo do usuário ao Cloudflare R2 via requisição HTTP PUT;

e) concluída a transferência, o navegador solicita o processamento e aguarda a resposta do servidor. A biblioteca Sharp verifica o conteúdo da imagem e gera uma miniatura WebP de até 400 px de largura, sem ampliar imagens menores. Essa operação não usa uma fila em segundo plano; as chaves retornadas são utilizadas no cadastro ou na atualização da obra ou do item de portfólio.

4.4.4 Assistente de Agendamento e Canal WhatsApp (PBI-31 a PBI-33)

Para equilibrar experiência de usuário e conformidade com a LGPD quanto ao tratamento de dados sensíveis de saúde (artigo 11 da Lei nº 13.709/2018), a equipe projetou o assistente de agendamento em etapas:

a) o assistente foi desenvolvido como um formulário em 8 etapas lineares executadas no lado do cliente: (1) Identificação, (2) Escolha do artista, (3) Estilo pretendido, (4) Região do corpo, (5) Dimensão estimada, (6) Data e horário de preferência, (7) Aceite obrigatório dos termos de conformidade e (8) Redirecionamento;

b) **sem persistência da solicitação de tatuagem:** os dados preenchidos são validados no servidor e usados para compor a mensagem, sem criar agendamento nem armazenar o conteúdo da solicitação. O controle de frequência das requisições utiliza registros técnicos na tabela rate_limit;

c) ***checks* de conformidade presencial:** os requisitos RF23, RF24 e RF25 são atendidos na Etapa 7 por caixas de seleção obrigatórias. O usuário declara ciência de que a anamnese clínica e o termo de consentimento serão preenchidos presencialmente no ateliê, além de confirmar sua maioridade civil;

d) **geração do *deep link* (wa.me):** ao concluir, o sistema concatena os dados em uma mensagem formatada e codificada para a URI oficial do WhatsApp do estúdio, permitindo que o diálogo final e o envio de referências visuais ocorram no canal direto entre cliente e profissional. Após o acordo, o tatuador cadastra o horário na agenda interna da plataforma (RF22).

4.4.5 Anonimização de Contas de Usuários em Atendimento à LGPD (PBI-40)

Para atender ao art. 16 da LGPD no encerramento da conta, eliminando os dados que identificam o titular e conservando o registro das vendas exigido pela legislação fiscal (ver Seção 2.5.3), foi implementada a ação transacional excluirPropriaConta, no módulo customers:

a) o cliente autenticado (papel CLIENTE, conta ativa) solicita o encerramento de sua conta e confirma a senha atual. A solicitação é recusada se houver pedido pago em andamento (PAGO, PROCESSANDO ou ENVIADO), pois o ateliê precisa do endereço para concluir a entrega;

b) em um único bloco transacional no PostgreSQL, com trava (FOR UPDATE) sobre a linha do usuário:

   – a linha do usuário em user recebe o marcador excluido_em e seus dados identificáveis são substituídos: nome = "Cliente excluído", email = "excluido-<id>@kolo.invalid" (domínio reservado, que não recebe mensagens e libera o e-mail original para um novo cadastro), telefone = null e imagem = null;

- pedidos aguardando pagamento são cancelados e suas reservas liberadas;
- sessões, credenciais, endereço, carrinho e códigos de recuperação de senha são removidos;
- a agenda perde o vínculo com a conta, e o registro de e-mails perde o destinatário;
- os pedidos em order são preservados, com número, itens, valores e datas. O *snapshot* de endereço (endereco_copia) é reduzido a cidade e UF, informações que não identificam o titular e servem ao registro da venda.

Dessa forma, remove-se o vínculo pessoal do titular com o sistema, preservando-se os dados necessários à contabilidade do ateliê.

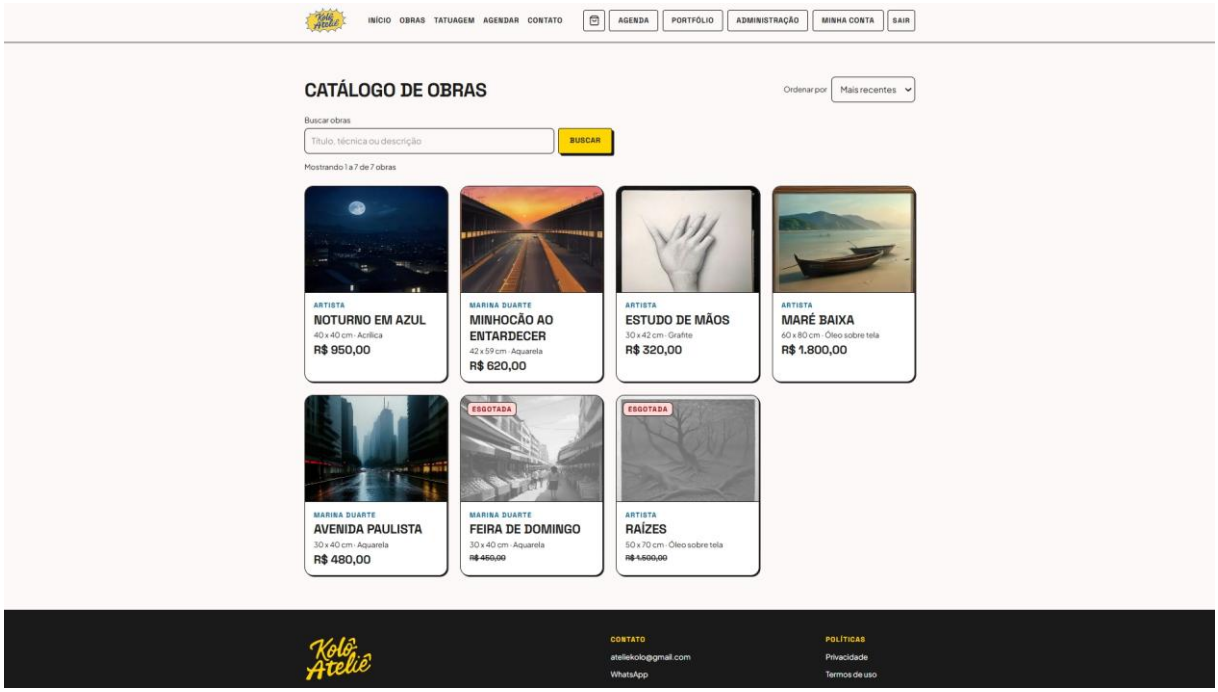
4.5 Apresentação das Interfaces do Sistema

As Figuras 4.7 a 4.13 apresentam sete telas essenciais do sistema implementado: descoberta de obras, decisão de compra, reserva para pagamento, avisos do assistente, portfólio, gestão de pedidos e relatório de vendas.

4.5.1 Catálogo de Obras de Arte

A Figura 4.7 evidencia a apresentação do acervo ao visitante, com busca, ordenação e identificação das obras disponíveis. O catálogo utiliza paginação e parâmetros na URL, com imagens renderizadas pelo componente de otimização do Next.js.

Figura 4.7 — Catálogo de Obras de Arte (RF09)

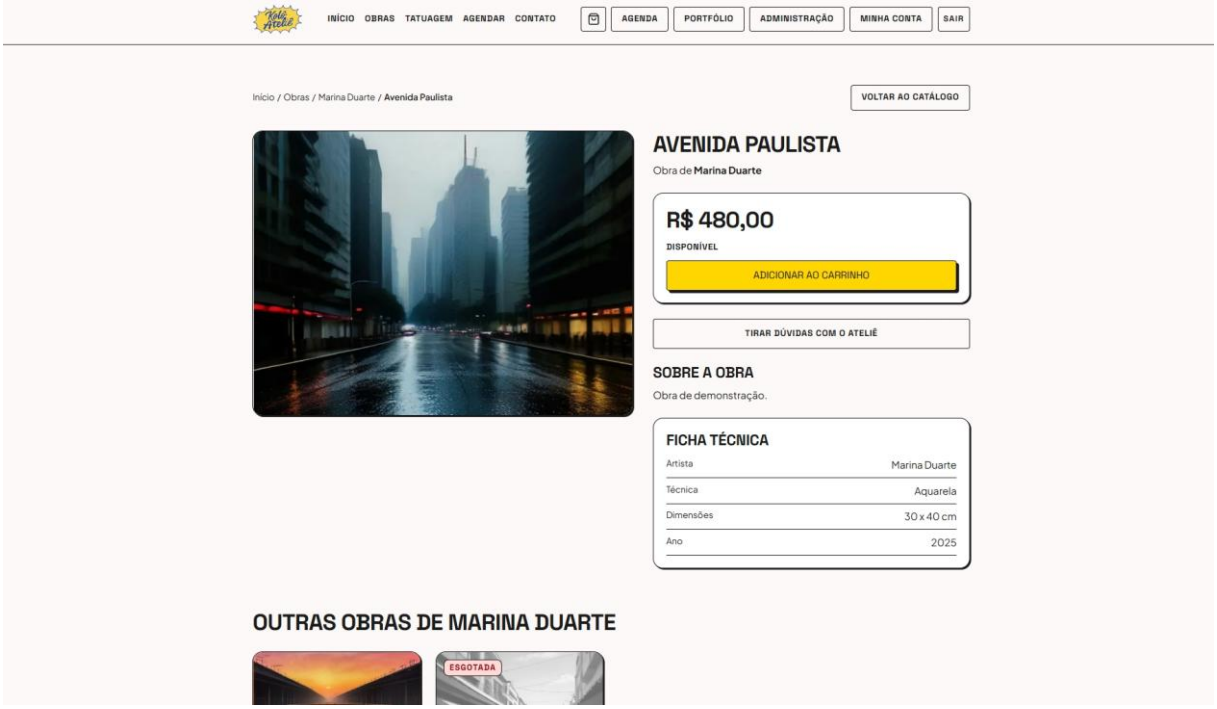


Fonte: Elaborado pelos autores (2026).

4.5.2 Ficha Detalhada da Obra

A Figura 4.8 mostra as informações usadas na decisão de compra: imagem principal, miniaturas, título, preço, disponibilidade e ficha técnica. A tela permite selecionar fotografias e adicionar uma obra disponível ao carrinho.

Figura 4.8 — Ficha Detalhada de uma Obra Disponível (RF10)

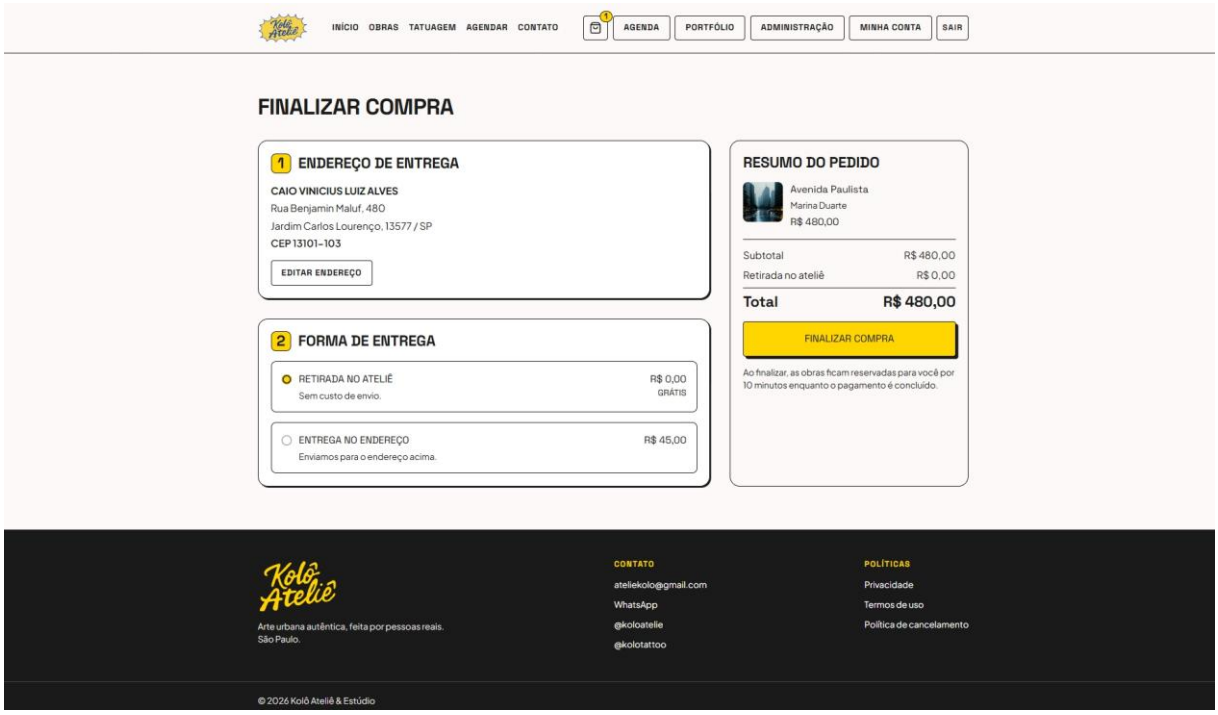


Fonte: Elaborado pelos autores (2026).

4.5.3 Pedido com Reserva e Início do Pagamento

O comprador revisa os itens e escolhe a modalidade de entrega em /checkout. Ao finalizar, o sistema cria o pedido e a reserva na mesma transação e direciona para /checkout/[numero]. A Figura 4.9 mostra essa segunda tela, com o resumo do pedido, o contador e a ação de pagar. O redirecionamento ao Checkout Pro ocorre somente ao acionar o pagamento; a confirmação posterior depende do *webhook*.

Figura 4.9 — Pedido com Reserva Ativa e Ação de Pagamento (RF12, RF13, RF15)



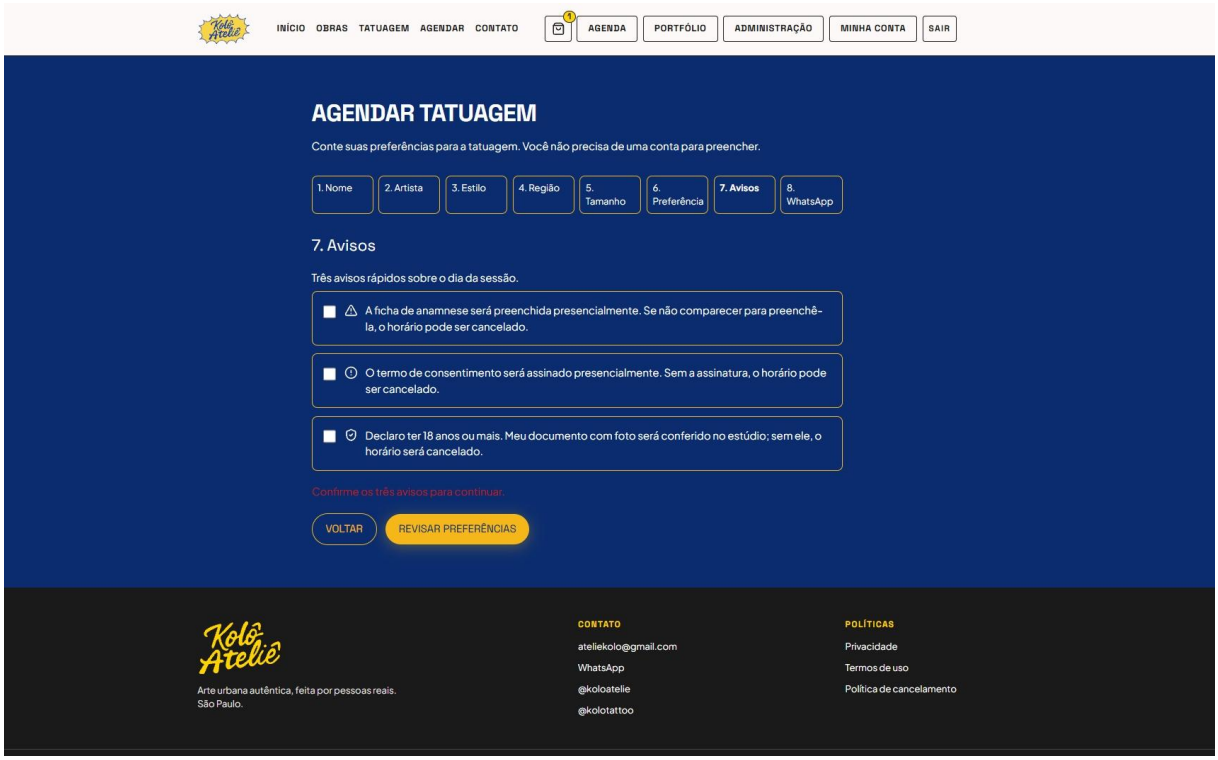
Fonte: Elaborado pelos autores (2026).

A reserva inicial tem duração de dez minutos, conforme RN03. O contador informa o prazo disponível para iniciar o pagamento; pagamentos pendentes por Pix ou boleto têm tratamento específico de prorrogação pelo *webhook*, descrito na Seção 4.4.2.

4.5.4 Assistente de Agendamento de Tatuagem

A Figura 4.10 mostra a etapa dos três avisos obrigatórios: preenchimento presencial da anamnese, assinatura presencial do termo e declaração de maioridade. Essa etapa evidencia os requisitos RF23 a RF25 sem coleta de dados clínicos. Após a revisão, o assistente disponibiliza o *link* para o WhatsApp do estúdio, sem criar automaticamente um agendamento.

Figura 4.10 — Avisos Obrigatórios do Assistente de Agendamento (RF20, RF23, RF24, RF25)

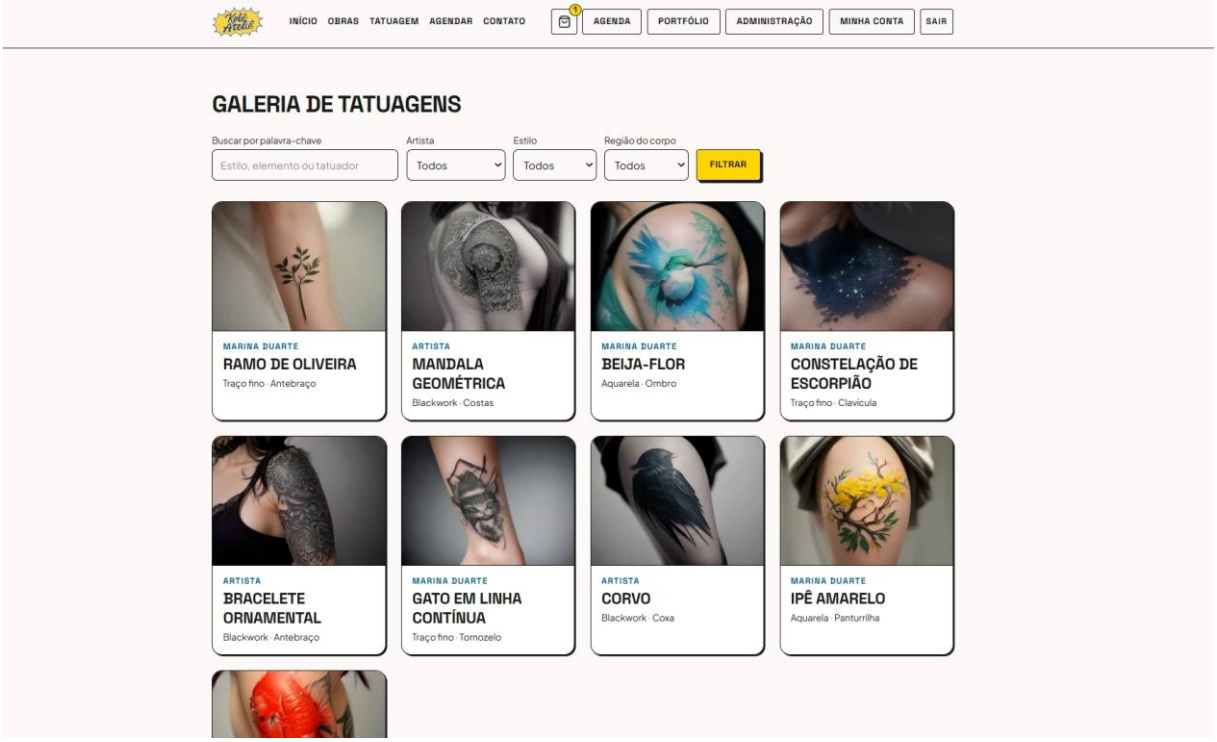


Fonte: Elaborado pelos autores (2026).

4.5.5 Portfólio de Tatuagens

A Figura 4.11 demonstra a consulta dos trabalhos dos artistas, com filtros e resultados da galeria. O portfólio complementa a seleção do profissional antes do contato pelo assistente.

Figura 4.11 — Galeria de Tatuagens com Filtros (RF17, RF18)

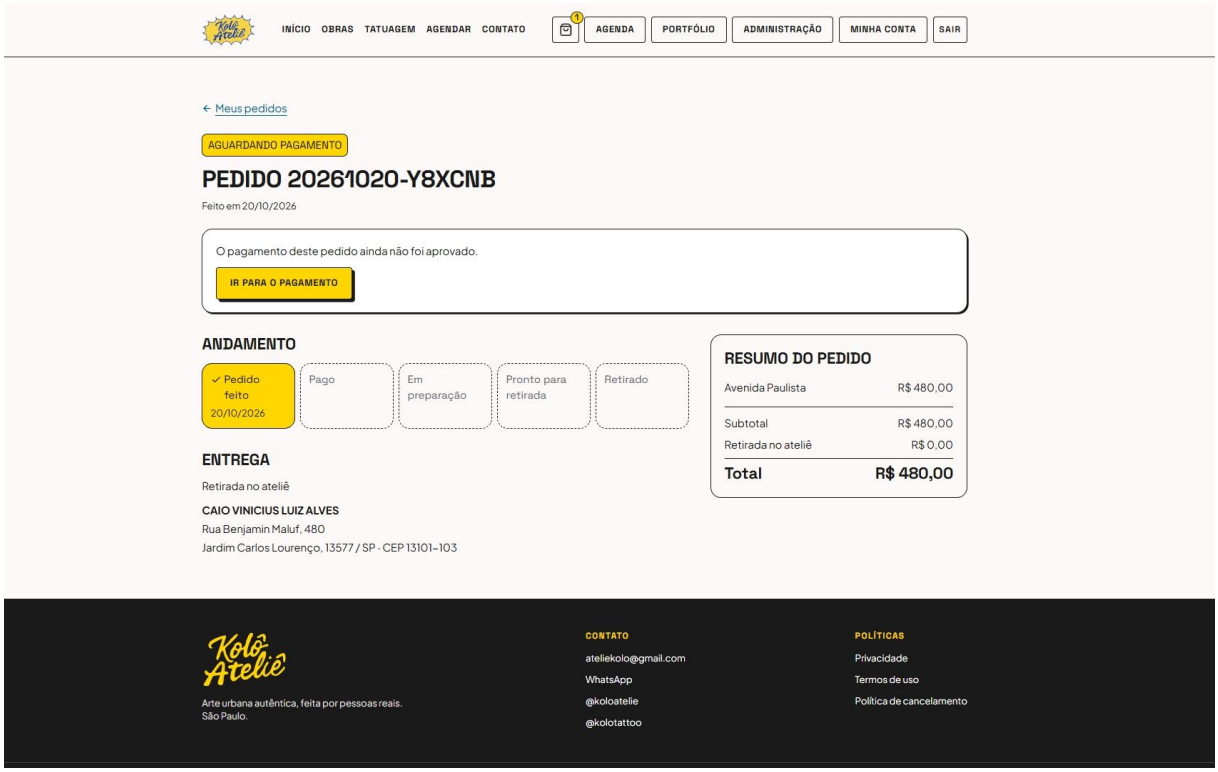


Fonte: Elaborado pelos autores (2026).

4.5.6 Gestão Administrativa de Pedidos

A Figura 4.12 apresenta o detalhe administrativo de um pedido, evidenciando sua situação, os itens e as ações de acompanhamento do envio. A lista administrativa também permite filtrar pedidos e localizar pagamentos que requerem estorno.

Figura 4.12 — Detalhe Administrativo de um Pedido para Entrega (RF29)

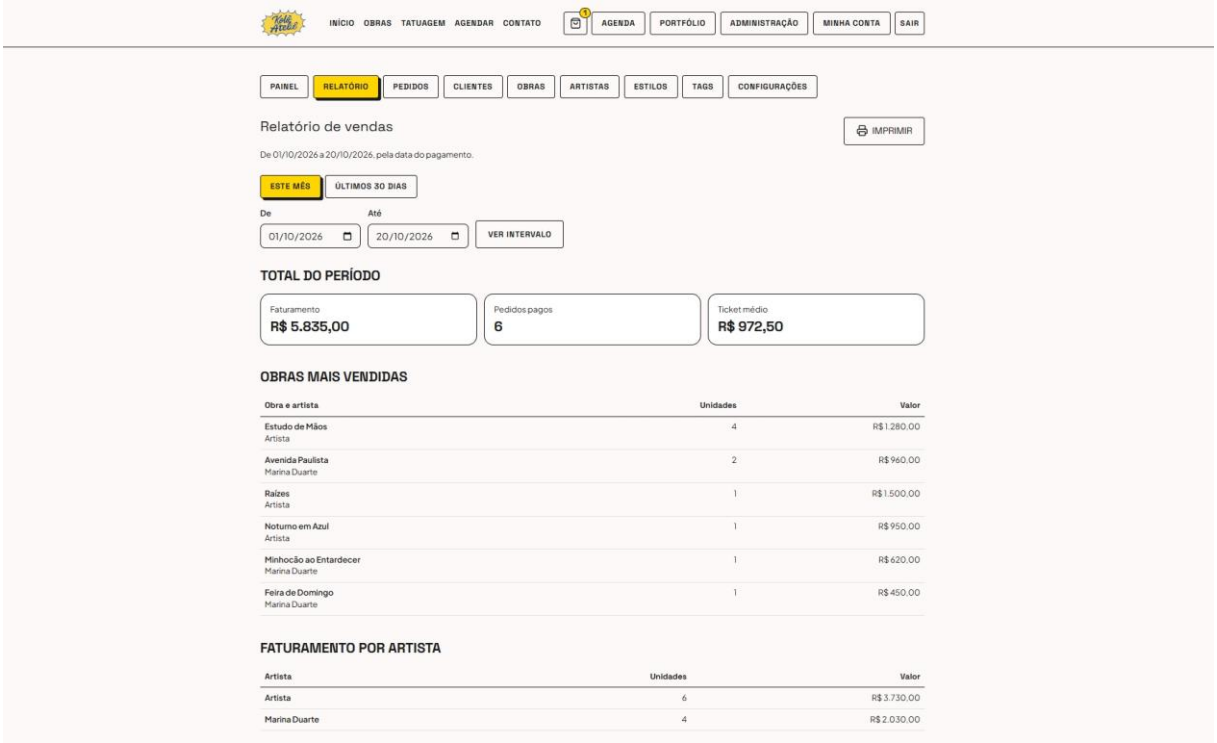


Fonte: Elaborado pelos autores (2026).

4.5.7 Relatório de Vendas

A Figura 4.13 mostra o relatório por período, que consolida os resultados de vendas e complementa o painel administrativo do RF32.

Figura 4.13 — Relatório Administrativo de Vendas por Período (RF32)



Fonte: Elaborado pelos autores (2026).

5 RESULTADOS E DISCUSSÃO

5.1 Estratégia de Testes e Cobertura Automatizada

A validação da plataforma Kolô fundamentou-se em uma abordagem de testes automatizados em múltiplas camadas, alinhada aos preceitos do Desenvolvimento Orientado a Testes (*Test-Driven Development* — TDD) preconizados por Beck (2002) e Pressman e Maxim (2021).

A estratégia contemplou três níveis complementares de verificação:

a) **testes unitários:** executados com o *framework* Vitest e a biblioteca React Testing Library sobre ambiente Node.js. Validam regras de negócio isoladas, esquemas Zod, funções de precificação monetária, assinaturas criptográficas de *webhooks* e estados de interface;

b) **testes de integração com banco de dados real:** executados contra uma instância real do motor PostgreSQL 17 rodando em contêiner Docker. Permitem atestar transações ACID, bloqueios pessimistas (SELECT ... FOR UPDATE), integridade referencial em cascata e restrições de exclusão temporal GiST (btree_gist), sem o mascaramento comum de bancos em memória;

c) **testes de ponta a ponta (E2E) e inspeção contínua (CI):** executados com Playwright cobrindo os fluxos críticos de navegação, *checkout*, preenchimento do assistente de agendamento e restrições de controle de acesso (RBAC), integrados ao GitHub Actions para validação a cada solicitação de integração (*Pull Request*).

A suíte completa de testes automatizados do projeto registrou:

a) 562 testes unitários aprovados, distribuídos em 122 arquivos de teste;

b) 276 testes de integração com PostgreSQL real aprovados sem falhas e 43 testes de ponta a ponta (E2E) no Playwright aprovados, ambos na rodada de fechamento de 18/10/2026, anterior ao PBI-48;

c) esteira de CI configurada com lint, format:check, typecheck, testes unitários, testes de integração, *build* e testes E2E. A execução de npm audit foi uma

verificação pontual registrada no fechamento do PBI-45, com zero vulnerabilidades altas ou críticas naquela medição; não integra o *workflow* automático versionado.

5.2 Rastreabilidade e Cobertura de Requisitos

O Quadro 5.1 estabelece a matriz de rastreabilidade do projeto Kolô, correlacionando cada um dos trinta e dois requisitos funcionais (RF01 a RF32) ao PBI correspondente, às suítes de testes automatizados responsáveis pela sua homologação e à situação final de atendimento.

Quadro 5.1 — Matriz de Rastreabilidade e Cobertura de Requisitos Funcionais

Requisito Funcional	**PBI de Entrega**	**Suíte de Testes Automatizados (Unitários e Integração)**	**Situação**
RF01 — Cadastro de clientes	*Sprint* 1	cadastro-schema.test.ts, cadastro-cliente.test.ts	Concluído
RF02 — Autenticação e sessão revogável	*Sprint* 1	formulario-login.test.tsx, sessao-better-auth.test.ts	Concluído
RF03 — Recuperação de senha por e-mail	*Sprint* 1	email-recuperacao.test.ts, recuperacao.test.ts	Concluído
RF04 — Edição de perfil cadastral	*Sprint* 1	perfil-schema.test.ts, perfil-cliente.test.ts	Concluído
RF05 — Endereço de entrega	PBI-23	endereco.test.ts, endereco.test.ts (integração)	Concluído
RF06 — Controle RBAC (Cliente/Artista/Admin)	*Sprint* 1	decidir-acesso.test.ts, admin-layout.test.tsx	Concluído
RF07 — Home com obras em destaque	PBI-21	pagina-home.test.tsx, vitrine-destaques.test.tsx	Concluído
RF08 — Páginas de políticas institucionais	PBI-22	documento-politica.test.tsx, rodape.test.tsx	Concluído
RF09 — Catálogo de obras em grade 2D	PBI-19	catalogo-regras.test.ts, pagina-catalogo.test.tsx	Concluído
RF10 — Ficha da obra e dados técnicos	PBI-20	detalhe-obra.test.tsx, pagina-obra.test.tsx	Concluído
RF11 — Carrinho de compras persistente	PBI-24	carrinho-regras.test.ts, carrinho.test.ts (integração)	Concluído
RF12 — *Checkout* e cálculo de entrega	PBI-26	checkout-regras.test.ts, checkout.test.ts (integração)	Concluído
RF13 — Pagamento Checkout Pro (Mercado Pago)	PBI-27	mercado-pago.test.ts, pagamento.test.ts (integração)	Concluído
RF14 — Confirmação automática via *webhook*	PBI-28	webhook-notificacao.test.ts, webhook-aprovacao.test.ts	Concluído
RF15 — Reserva de estoque temporária (10 min)	PBI-25	pedido-checkout.test.tsx, reserva.test.ts (integração)	Concluído

Requisito Funcional	PBI de Entrega	Suíte de Testes Automatizados (Unitários e Integração)	Situação
RF16 — Rastreio e histórico de pedidos	PBI-29	detalhe-pedido.test.tsx, pedidos-cliente.test.ts	Concluído
RF17 — Galeria de portfólio de tatuagens	PBI-36	pagina-galeria.test.tsx, galeria-publica.test.ts	Concluído
RF18 — Busca textual no portfólio	PBI-37	busca.test.ts, catalogo-busca.test.ts (integração)	Concluído
RF19 — Gestão de fotos de portfólio	PBI-35	portfolio-upload.test.tsx, portfolio.test.ts	Concluído
RF20 — Assistente de agendamento em etapas	PBI-31	wizard-validacao.test.ts, wizard-agendamento.test.tsx	Concluído
RF21 — Redirecionamento com *link* wa.me	PBI-33	link-whatsapp.test.ts, mensagem-agendamento.test.ts	Concluído
RF22 — Cadastro manual de horários na agenda	PBI-34	agenda-regras.test.ts, agenda.test.ts (integração)	Concluído
RF23 — Alerta obrigatório de anamnese	PBI-32	wizard-avisos.test.tsx	Concluído
RF24 — Alerta de termo de consentimento	PBI-32	wizard-avisos.test.tsx	Concluído
RF25 — Declaração obrigatória de maioridade	PBI-32	wizard-avisos.test.tsx	Concluído
RF26 — CRUD administrativo de obras de arte	PBI-18	gestao-obras.test.tsx, catalogo-obras.test.ts	Concluído
RF27 — *Upload* direto ao Cloudflare R2	PBI-17	upload-imagem.test.tsx, media-assinatura.test.ts	Concluído
RF28 — Gestão de artistas, estilos e *tags*	PBI-16	gestao-artistas.test.tsx, artistas.test.ts (integração)	Concluído
RF29 — Painel de despacho e gestão de pedidos	PBI-30	pedido-admin.test.tsx, pedidos-admin.test.ts	Concluído
RF30 — Visualização administrativa de clientes	PBI-38	lista-clientes-admin.test.tsx, perfil-cliente.test.ts	Concluído
RF31 — Configuração institucional do site	PBI-39	configuracao-site.test.ts, configuracao-site.test.ts (integração)	Concluído
RF32 — Painel de indicadores e relatório de vendas	PBI-48	painel-admin.test.tsx, relatorio-vendas.test.tsx, painel-admin.test.ts (integração), relatorio-vendas.test.ts (integração)	Concluído

Fonte: Elaborado pelos autores (2026).

Cada um dos 32 requisitos funcionais possui ao menos um teste automatizado associado, aprovado na rodada de fechamento ou, no caso do RF32, na integração do PBI-48 (19/10/2026).

5.3 Avaliação Experimental de Concorrência e Integridade de Estoque

A verificação do requisito de concorrência transacional (RN04) constituiu um dos experimentos centrais da pesquisa. Tratando-se de um comércio especializado em peças exclusivas (cujo estoque disponível frequentemente equivale a Q = 1), uma falha no isolamento de transações resultaria em venda duplicada (*overselling*).

5.3.1 Desenho do Experimento

Para avaliar o comportamento da reserva sob concorrência, estruturou-se um teste automatizado de integração que chama diretamente a função de reserva contra uma instância real do PostgreSQL 17, sem passar pela camada HTTP da aplicação. Os parâmetros do experimento foram os seguintes:

a) **cenário:** 8 sessões distintas, abertas para um mesmo cliente de teste, como abas ou aparelhos diferentes. Como a regra de reserva desconta apenas as reservas de outras sessões, cada sessão disputa a obra como um comprador independente;

b) **objeto em disputa:** uma obra recém-publicada com estoque unitário (Q = 1);

c) **ação concorrente:** as 8 sessões solicitam a reserva de uma unidade da obra com chamadas disparadas em paralelo, todas com o mesmo instante de referência para o cálculo da expiração;

d) **repetições:** o teste executou 10 rodadas consecutivas, cada uma com uma nova obra, para que o resultado não dependesse de uma única disputa.

5.3.2 Análise dos Dados e Resultados Obtidos

Os dados observados nas 10 rodadas de disputa concorrente estão consolidados na Tabela 5.1.

Tabela 5.1 — Resultados do Experimento de Concorrência de Reserva de Estoque

Rodada	Sessões em Concorrência	Quantidade em Estoque	Reservas Concedidas	Reservas Recusadas (indisponivel)	Total no Banco (artwork_reservation)
1	8	1	1	7	1

Rodada	Sessões em Concorrência	Quantidade em Estoque	Reservas Concedidas	Reservas Recusadas (indisponivel)	Total no Banco (artwork_reservation)
2	8	1	1	7	1
3	8	1	1	7	1
4	8	1	1	7	1
5	8	1	1	7	1
6	8	1	1	7	1
7	8	1	1	7	1
8	8	1	1	7	1
9	8	1	1	7	1
10	8	1	1	7	1
Total	**80 tentativas**	—	**10 aprovadas (12,5%)**	**70 recusadas (87,5%)**	**Exatamente 1 por obra**

Fonte: Elaborado pelos autores (2026), com dados da execução de tests/integration/reserva.test.ts.

As verificações do teste indicaram:

a) **reservas concedidas:** em todas as 10 rodadas, exatamente uma sessão obteve a reserva, e as outras 7 receberam a resposta de obra indisponível;

b) **total reservado:** a consulta à tabela de reservas mostrou que a soma das unidades reservadas para cada obra foi igual a 1, sem ultrapassar o estoque;

c) **impasses:** o teste concluiu as 10 rodadas sem erro e sem impasse (*deadlock*). Como cada transação desse experimento trava uma única obra, o cenário não exercita a ordenação dos identificadores, relevante apenas quando o carrinho contém várias obras. Esse caso não foi testado sob concorrência.

O experimento fornece evidência de que, nas condições descritas, o bloqueio pessimista impediu a venda duplicada de uma peça única sob reservas concorrentes. Ele não fornece evidência sobre a prevenção de impasses em carrinhos com várias obras.

5.4 Métricas de Desempenho e Acessibilidade

O atendimento aos requisitos não funcionais de experiência do usuário e qualidade de software foi mensurado por meio de ferramentas de auditoria.

5.4.1 Auditoria de Desempenho *Web* (Google Lighthouse)

Em atendimento ao requisito RNF13, que estabelece que o catálogo de obras e a ficha técnica devem atingir o marco de *Largest Contentful Paint* (LCP) abaixo de 2,5 segundos sob condições simuladas de rede móvel (Lighthouse 12.8.2, perfil *mobile* com 4G simulado, mediana de 3 rodadas), foram apuradas as métricas oficiais registradas na *Sprint* 2 (PBI-45).

A Tabela 5.2 apresenta as métricas apuradas.

Tabela 5.2 — Métricas de Desempenho e Qualidade *Web* (Lighthouse 12.8.2, Mediana de 3 Rodadas)

Indicador Técnico	**Meta Estabelecida**	**Catálogo de Obras**	**Ficha da Obra**	**Situação**
Desempenho Geral (Pontuação)	≥ 90	97 (rodadas: 98/94/97)	98 (rodadas: 98/98/92)	Aprovado
Largest Contentful Paint (LCP)	< 2,5 s	2,43 s	2,25 s	Aprovado
First Contentful Paint (FCP)	< 1,8 s	0,78 s	0,78 s	Aprovado
Total Blocking Time (TBT)	< 200 ms	73 ms	83 ms	Aprovado
Cumulative Layout Shift (CLS)	< 0,10	0	0	Aprovado
Acessibilidade Geral (Pontuação)	≥ 90	98	100	Aprovado
Boas Práticas de Engenharia	≥ 90	100	100	Aprovado
Search Engine Optimization (SEO)	≥ 90	100	100	Aprovado

Fonte: Elaborado pelos autores (2026), com dados registrados no repositório (docs/Sprint-2.md, PBI-45).

Observa-se que:

a) o catálogo atendeu à meta de LCP com margem de 70 ms (2,43 s frente à meta de 2,5 s), decorrente da otimização que restringiu a prioridade de carregamento (priority) estritamente à primeira foto da grade, mantendo as demais sob carregamento diferido (*lazy loading*);

b) a pontuação de acessibilidade de 98 no catálogo deve-se à ordem hierárquica de cabeçalhos (heading-order), regra de boas práticas que não impede a conformidade WCAG A/AA;

c) o deslocamento de *layout* foi nulo (CLS = 0) pela reserva prévia de dimensões de imagem no CSS.

5.4.2 Avaliação de Acessibilidade Digital (WCAG 2.1 AA / axe-core)

O requisito RNF21 foi avaliado parcialmente por meio do motor axe-core em 35 telas da aplicação. O teste tests/e2e/varredura.spec.ts seleciona regras WCAG 2.0 e 2.1 dos níveis A/AA, executa a análise nas larguras de 320 e 1440 px e considera violações de impacto crítico ou sério:

a) **resultado da varredura:** a rodada registrada no PBI-45 não apresentou violações críticas ou sérias no recorte avaliado, incluindo verificações automáticas de contraste e de atributos de acessibilidade;

b) **navegação por teclado e foco visível:** a verificação dos fluxos principais ficou pendente no PBI-45. A varredura automatizada não demonstra, por si só, que todas as tarefas podem ser concluídas por teclado;

c) **limites da avaliação:** resultados classificados pelo axe como inconclusivos e violações de outros níveis de impacto não integram o critério de reprovação desse teste; o iframe externo do Turnstile também é excluído da análise. Não foi realizada avaliação com usuários com deficiência.

Esses resultados constituem evidência de verificação automatizada parcial, sem atestar conformidade integral com a WCAG 2.1 AA.

5.5 Validação Qualitativa com o Estabelecimento Parceiro

A etapa de avaliação qualitativa com o Kolô Ateliê & Estúdio realizou-se em 10 de outubro de 2026, com a participação da administradora e tatuadora do estabelecimento, Melanie Schwark, e dos integrantes da equipe de desenvolvimento. A sessão utilizou uma versão do sistema anterior às correções finais do PBI-43 (tratamento de estornos) e do PBI-45 (qualidade integrada, segurança e acessibilidade), realizadas entre 12 e 18/10/2026; os resultados quantitativos da Seção 5.4 referem-se à versão final.

Durante a sessão assistida, a administradora executou as tarefas centrais do sistema em ambiente local homologado:

a) navegação no catálogo de obras e verificação da ficha técnica;

b) simulação de compra no *checkout* com teste das modalidades de retirada no ateliê e entrega postal com frete, utilizando o ambiente de *sandbox* do Mercado Pago;

c) preenchimento do assistente de agendamento de tatuagem em etapas, confirmando os alertas obrigatórios de anamnese e consentimento informado até a geração do *link* direcionado para o WhatsApp;

d) inclusão manual de horário na agenda interna do artista residente, verificando a recusa em caso de horários concorrentes.

5.5.1 Síntese do Retorno do Cliente

A administradora expressou satisfação com o *design* visual da plataforma, destacando a coerência com a identidade estética do ateliê e a fluidez da navegação entre as seções.

Como oportunidade de aprimoramento, sugeriu ajustes pontuais nos textos descritivos das obras de arte e no detalhamento das orientações institucionais. As sugestões foram registradas e incorporadas pela equipe nos arquivos de configuração do módulo settings e nas políticas do sistema.

A administradora avaliou positivamente o modelo do assistente de agendamento que direciona o contato formatado ao WhatsApp sem reter prontuários médicos no sistema, considerando-o adequado à rotina do estúdio e protetivo quanto às exigências da LGPD.

5.6 Discussão dos Resultados, Dificuldades e Limitações

Esta seção confronta a hipótese com os dados obtidos e discute as dificuldades e limitações do trabalho.

5.6.1 Validação da Hipótese de Pesquisa

A hipótese deste trabalho reunia três afirmações: a plataforma eliminaria os controles manuais de comercialização identificados no diagnóstico, preveniria vendas duplicadas de peças exclusivas e qualificaria o atendimento inicial do Kolô. Cada uma é examinada a seguir à luz da evidência obtida e da literatura.

A primeira afirmação sustentava que a centralização do catálogo e o processamento automatizado de pedidos eliminariam os controles manuais. As evidências obtidas referem-se ao funcionamento do sistema. Os 32 requisitos funcionais foram associados a testes automatizados (Quadro 5.1), e a Seção 5.1 registra 562 testes unitários, 276 testes de integração com PostgreSQL real e 43 testes de ponta a ponta aprovados. As contagens de integração e de ponta a ponta são anteriores à entrega do relatório de vendas (RF32). O catálogo e a ficha da obra atingiram LCP de 2,43 s e 2,25 s, abaixo da meta de 2,5 s. Esses dados indicam que os fluxos de catálogo, pedido e pagamento se comportam como especificado nas condições de teste. Eles não permitem afirmar que os controles manuais foram eliminados, porque o sistema ainda não foi implantado nem usado na rotina do ateliê.

Quanto ao processo de desenvolvimento, a escrita de testes antes do código aproxima este trabalho do estudo de Nagappan *et al.* (2008). Aqueles autores observaram redução de 40% a 90% na densidade de defeitos, com aumento de 15% a 35% no tempo inicial de desenvolvimento. Neste trabalho, a densidade de defeitos e o tempo de desenvolvimento não foram medidos. A comparação é, portanto, apenas qualitativa e não confirma aqueles percentuais. Da mesma forma, a esteira de integração contínua foi configurada para executar verificações a cada solicitação de integração, mas os custos e benefícios estudados por Hilton *et al.* (2016) não foram avaliados aqui.

A segunda afirmação sustentava que a reserva temporária com bloqueio transacional preveniria vendas duplicadas. A evidência provém de um teste de integração da função de reserva executado contra o PostgreSQL real, e não de requisições HTTP à aplicação. Em 10 rodadas, 8 sessões de um mesmo cliente de teste disputaram simultaneamente uma obra com estoque 1. Em cada rodada, uma reserva foi concedida e sete foram recusadas, o que totaliza 80 tentativas, 10

aprovadas e 70 recusadas. A soma reservada no banco nunca passou de 1, e nenhum impasse ocorreu.

Esse resultado é coerente com a literatura. A atualização perdida, descrita por Berenson *et al.* (1995) e Kleppmann (2017), não se manifestou sob o bloqueio pessimista. Nenhum impasse ocorreu, mas cada transação travava uma única obra, de modo que o experimento não exercitou a ordenação dos recursos recomendada por Silberschatz, Korth e Sudarshan (2020). O alcance da evidência é, portanto, limitado. O experimento usou 8 sessões e uma única instância de banco, não mediu latência e não testou carga maior nem carrinhos com várias obras. Nessas condições, os testes indicaram que a regra de reserva impediu a venda duplicada, mas não descrevem o comportamento da aplicação completa sob tráfego real.

A terceira afirmação sustentava que o assistente de agendamento em etapas qualificaria o atendimento inicial. A evidência disponível é qualitativa e vem de uma única participante. Em 10/10/2026, a administradora e tatuadora Melanie Schwark avaliou uma versão anterior às correções finais e deu retorno positivo sobre a identidade visual, a navegação e o assistente de agendamento. A redução do tempo de atendimento, contudo, não foi medida, e a qualificação do atendimento depende de medição após a implantação.

A acessibilidade condiciona quem consegue usar esse atendimento on-line. A varredura com axe-core não reportou violações críticas ou sérias em 35 telas, resultado que deve ser lido com cautela. Vigo, Brown e Conway (2013) mostraram que ferramentas automáticas cobrem apenas parte dos critérios da WCAG. Guimarães (2016), por sua vez, encontrou em lojas brasileiras barreiras de navegação que chegaram a impedir a conclusão de uma compra por usuários cegos. A ausência de violações automáticas não equivale, portanto, a acessibilidade plena, sobretudo porque a navegação por teclado ficou pendente e não houve avaliação com usuários com deficiência.

Somadas, as evidências sustentam parcialmente a hipótese. A prevenção de vendas duplicadas tem a evidência mais forte, obtida em experimento controlado contra o banco real, ainda que em escala reduzida. A eliminação dos controles manuais tem evidência de que os fluxos digitais funcionam, mas não de que tenham substituído a rotina do ateliê. A qualificação do atendimento conta apenas com indícios

qualitativos de uma participante. Parte desse alcance foi condicionada pelo modo como o sistema pôde ser testado antes da implantação, aspecto relacionado às dificuldades técnicas relatadas na Seção 5.6.2.

5.6.2 Dificuldades Técnicas Vivenciadas

Ao longo do desenvolvimento, a equipe enfrentou os seguintes desafios:

a) **simulação e testes de *webhooks*:** a validação de *webhooks* do *gateway* em ambiente de desenvolvimento local exigiu o uso de túneis reversos e a geração de assinaturas compatíveis com o validador oficial do SDK do Mercado Pago;

b) **políticas de CORS no *upload* direto ao R2:** a realização de *uploads* diretos do navegador para o Cloudflare R2 via URLs pré-assinadas demandou a harmonização das regras de CORS do *bucket* com as origens locais de teste;

c) **casos de borda em pagamentos (PBI-43):** identificou-se a necessidade de tratar o cenário no qual um pedido gera um pagamento Pix e, posteriormente, uma tentativa de quitação concorrente. A solução implementada marca o pagamento com o motivo de estorno e o exibe na fila “Estorno pendente” do painel administrativo, resguardando o controle financeiro;

d) **divergência entre o planejado e o executado nas *sprints*:** a *Sprint* 1, planejada para uma semana, estendeu-se por cerca de quatro semanas, o que evidencia a subestimação do esforço inicial. A *Sprint* 2 incorporou esse aprendizado: o planejamento passou a tratar as janelas de datas como metas de acompanhamento, e não como estimativas validadas, com priorização dos itens P0 e execução em paralelo dos PBIs independentes (docs/Sprint-2.md).

5.6.3 Limitações do Estudo

Apontam-se as seguintes limitações do trabalho:

a) **validação financeira em *sandbox*:** as transações financeiras foram processadas sobre o ambiente de testes (*sandbox*) do Mercado Pago com compradores simulados, haja vista que a ativação de credenciais finais de produção depende de trâmites bancários de pessoa jurídica do ateliê;

b) **ambiente de testes pré-deploy:** as métricas de desempenho e acessibilidade foram coletadas localmente sobre o *build* de produção (next start) executado em Node.js, com PostgreSQL em contêiner Docker, estando o *deploy* público na VPS (PBI-46) e a homologação com cartões reais (PBI-47) programados para a etapa subsequente que antecede a banca examinadora;

c) **acessibilidade verificada de forma automatizada:** parte dos critérios WCAG 2.1 A/AA foi avaliada com o motor axe-core, sem avaliação com usuários com deficiência e com verificação de navegação por teclado e foco ainda pendente. Como mostram Vigo, Brown e Conway (2013), ferramentas automáticas cobrem apenas parte dos critérios da WCAG, e Guimarães (2016) evidenciou que testes com usuários cegos revelam barreiras concretas de navegação e de conclusão de compra. A ausência de violações reportadas pelo motor, portanto, não equivale à acessibilidade plena do sistema;

d) **escopo deliberadamente postergado (v2.2):** funcionalidades acessórias — como o visualizador 3D para esculturas e a integração bidirecional com a API do Google Calendar — foram conscientemente postergadas para trabalhos futuros, priorizando a estabilidade do fluxo de compras e a conformidade legal.

6 CONCLUSÃO

Este capítulo retoma o problema de pesquisa e indica qual resposta as evidências dos Capítulos 4 e 5 permitem sustentar. Para isso, examina o atendimento aos objetivos, a hipótese, as contribuições, as limitações do estudo e os trabalhos futuros.

6.1 Atendimento aos Objetivos da Pesquisa

O problema de pesquisa (Seção 1.2) perguntava como uma plataforma *web* em monólito modular poderia resolver o controle manual das vendas de obras e estruturar a triagem de agendamentos de tatuagem do Kolô. A pergunta incluía duas condições: integridade transacional do estoque e conformidade com a legislação de proteção de dados. As evidências dos Capítulos 4 e 5 permitem responder em dois níveis: a plataforma foi construída e verificada em ambiente de teste, mas ainda não passou pela implantação em produção.

Cinco objetivos específicos foram realizados. Os requisitos foram levantados com a administradora e os artistas residentes e organizados em 32 requisitos funcionais, 24 não funcionais e 12 regras de negócio (1). O módulo de comércio eletrônico reúne vitrine, carrinho persistente e *checkout* com retirada no ateliê ou entrega postal, integrado ao Mercado Pago Checkout Pro (3). A reserva temporária de dez minutos com bloqueio pessimista foi implementada, e o experimento da Seção 5.3 não registrou venda duplicada em 80 tentativas concorrentes (4). O assistente de agendamento em oito etapas exige os aceites de anamnese e de consentimento presenciais e gera o *link* para o WhatsApp do estúdio sem armazenar dados de saúde (5). Os módulos de retaguarda incluem a gestão do acervo, o despacho com código de rastreamento, a agenda interna, o relatório de vendas e a anonimização do cadastro na exclusão de conta (6). Esses resultados respondem à parte do problema que depende do software: estoque, pedido e triagem passaram a contar com fluxos digitais definidos e testados.

Dois objetivos foram parcialmente realizados, e ambos dependem da implantação em produção. No projeto da arquitetura (2), o monólito modular, o modelo relacional e o banco em contêiner foram concluídos. Faltam a conteinerização da

aplicação, o *proxy* reverso com TLS no servidor público, a rotina de *backup* do banco e o monitoramento de erros em produção, que estão apenas projetados (Quadro 4.2). Na verificação e validação (7), foram executados 562 testes unitários, 276 testes de integração com PostgreSQL real e 43 testes de ponta a ponta. Também foram realizadas as auditorias de desempenho e acessibilidade e a sessão de validação com a administradora. Falta a homologação com pagamentos reais, pois os pagamentos foram validados apenas no ambiente de testes do Mercado Pago. Enquanto essas etapas não forem concluídas, a resposta ao problema permanece restrita ao ambiente de teste.

6.2 Avaliação da Hipótese de Pesquisa

A hipótese afirmava que a plataforma eliminaria os controles manuais de comercialização, preveniria vendas duplicadas de peças exclusivas e qualificaria o atendimento inicial do Kolô. As três partes não contam com o mesmo tipo de evidência, e essa diferença define o alcance da conclusão.

A prevenção de venda duplicada foi demonstrada em ambiente de teste. No experimento de integração contra o PostgreSQL real, apenas uma de 8 reservas concorrentes foi confirmada para cada peça unitária, em 10 rodadas, e a soma reservada nunca passou de 1. Nenhum impasse ocorreu, mas, como cada transação travava uma única obra, a ordenação contra impasses não foi exercitada. O resultado é coerente com o que a literatura descreve para o bloqueio pessimista. Ainda assim, ele vale para as condições do experimento, que não incluíram carga maior nem carrinhos com várias obras.

As outras duas partes dependem de uso real. Os testes indicaram que os fluxos de acervo, pedido e pagamento funcionam como especificado, mas não mostram que os controles manuais em redes sociais deixaram de ser usados, pois o sistema não foi implantado. Da mesma forma, a administradora deu retorno positivo sobre o assistente de agendamento, mas essa é uma avaliação qualitativa de uma única participante, feita numa versão anterior às correções finais. A redução do tempo de atendimento não foi medida e só pode ser verificada com o sistema em uso.

Por isso, a hipótese é sustentada parcialmente. A parte técnica foi demonstrada em ambiente de teste, e as partes operacionais permanecem como expectativa a ser verificada após a implantação em produção.

6.3 Contribuições do Trabalho

As contribuições do trabalho dividem-se em práticas, voltadas ao Kolô, e técnicas, voltadas à Engenharia de Software.

6.3.1 Contribuições Práticas e Econômicas

Para o Kolô Ateliê & Estúdio, o sistema desenvolvido oferece as bases listadas a seguir, cujo efeito na rotina do ateliê depende da implantação em produção:

a) um canal de vendas assíncrono para o acervo físico de arte, complementar ao atendimento presencial no ateliê;

b) um canal próprio, que reduz a dependência das condições comerciais e de apresentação de plataformas generalistas de terceiros;

c) uma apresentação visual alinhada à identidade estética do estúdio, avaliada positivamente pela administradora (Seção 5.5);

d) decisões de projeto voltadas à LGPD: coleta mínima de dados cadastrais, ausência de dados de saúde no sistema e anonimização do cadastro na exclusão de conta.

6.3.2 Contribuições Técnicas e Acadêmicas

No âmbito da Engenharia de Software, o projeto oferece:

a) um caso de aplicação da arquitetura de monólito modular sobre Next.js 16 e Node.js 24 LTS, com tipagem estática compartilhada entre servidor e cliente e transações ACID locais, em um ambiente de manutenção acessível a pequenos negócios;

b) a aplicação do bloqueio pessimista ao controle de estoque unitário (Q = 1) em peças de arte física, com ordenação dos recursos contra impasses. O

experimento da Seção 5.3 avaliou a reserva concorrente de uma obra, mas não a ordenação em carrinhos com várias obras;

c) a aplicação do conceito de *Privacy by Design*, mostrando como a engenharia de requisitos pode evitar a coleta de dados de saúde por meio de um assistente de agendamento em etapas direcionado a um canal direto;

d) uma esteira de integração contínua com testes automatizados em três níveis: 562 testes unitários, 276 testes de integração com banco relacional real e 43 testes de ponta a ponta. As contagens de integração e de ponta a ponta são anteriores à entrega do relatório de vendas (RF32), e esses resultados não substituem a reexecução das suítes na versão atual.

6.4 Limitações do Estudo

As conclusões deste trabalho têm limites que decorrem do modo como o sistema pôde ser avaliado. Os pagamentos foram validados apenas no ambiente de testes do Mercado Pago, com compradores simulados; por isso, o comportamento com cartões e contas reais não foi observado. As métricas de desempenho e acessibilidade foram coletadas em ambiente local, antes da implantação pública, e podem variar no servidor de produção, sob rede e carga reais. O visualizador 3D para esculturas e a integração com o Google Calendar foram postergados, de modo que as conclusões não abrangem essas funcionalidades.

A acessibilidade foi verificada apenas de forma automática, sem a participação de usuários com deficiência e com a verificação de teclado e foco pendente. Como mostram Vigo, Brown e Conway (2013) e Guimarães (2016), esse tipo de verificação cobre apenas parte das barreiras, e o resultado não permite afirmar que o sistema seja acessível. A validação qualitativa contou com uma única participante, usou uma versão anterior às correções finais e não empregou instrumento de medição; seu resultado indica aceitação, mas não pode ser generalizado. Por fim, a redução do tempo de atendimento não foi medida, e a terceira parte da hipótese permanece sem verificação quantitativa. Superar essas limitações depende da implantação em produção e de medições com o sistema em uso, frentes incluídas entre os trabalhos futuros da Seção 6.5.

6.5 Trabalhos Futuros

Os trabalhos futuros dividem-se em duas frentes. As três primeiras respondem às limitações da Seção 6.4, e as demais ampliam as funcionalidades da plataforma:

a) **implantação em produção:** conteinerização da aplicação, *proxy* reverso com TLS, rotina de *backup* do banco, monitoramento de erros e homologação com pagamentos reais, etapas já projetadas (Quadro 4.2);

b) **avaliação com o sistema em uso:** medição do tempo de atendimento após a implantação, verificação da navegação por teclado e do foco visível, avaliação de acessibilidade com usuários com deficiência e validação com mais participantes;

c) **ampliação dos testes de concorrência:** disputas envolvendo carrinhos com várias obras, para exercitar a ordenação contra impasses, e cenários com carga maior e medição de latência;

d) **visualizador 3D interativo para esculturas:** reintrodução da renderização 3D via Three.js / WebGL na ficha de produtos exclusivamente para obras tridimensionais (esculturas e cerâmicas), com modelos poligonais otimizados para não impactar o tempo de carregamento;

e) **motor algorítmico de gestão de *slots* de agendamento:** evolução da agenda interna com parametrização de intervalos de preparação entre sessões e sincronização opcional com calendários pessoais dos artistas via protocolos iCalendar / CalDAV;

f) **módulo de notificações ativas via WhatsApp:** avaliação da API Oficial da Meta (WhatsApp Business Cloud API) para disparo de lembretes prévios de sessão e código de rastreamento postal diretamente no aplicativo de mensagens;

g) **evolução do painel de indicadores:** ampliação do painel e do relatório de vendas implementados (RF32) com gráficos, comparação entre períodos, exportação em CSV e visão restrita para cada artista;

h) **autenticação social federada:** inclusão de provedores de identidade externos (Google e Apple) integrados ao Better Auth para simplificação de cadastro.

REFERÊNCIAS

AL-QORA'N, Lamis F.; AL-SAID AHMAD, Amro. Modular monolith architecture in cloud environments: a systematic literature review. **Future Internet**, Basel, v. 17, n. 11, art. 496, 2025. DOI: 10.3390/fi17110496.

ANDERSON, Ross. **Security engineering**: a guide to building dependable distributed systems. 3. ed. Indianapolis: John Wiley & Sons, 2020.

ARTSY. **Applications**. [S. l.], [2026]. Disponível em: https://apply.artsy.net/partnerships. Acesso em: 27 ago. 2026.

BACCHELLI, Alberto; BIRD, Christian. Expectations, outcomes, and challenges of modern code review. In: INTERNATIONAL CONFERENCE ON SOFTWARE ENGINEERING, 35., 2013, San Francisco. **Proceedings** [...]. Piscataway: IEEE, 2013. p. 712-721. DOI: 10.1109/ICSE.2013.6606617.

BANKS, Alex; PORCELLO, Eve. **Learning React**: modern patterns for developing React apps. 2. ed. Sebastopol: O'Reilly Media, 2020.

BECK, Kent. **Test-driven development**: by example. Boston: Addison-Wesley, 2002.

BERENSON, Hal *et al.* A critique of ANSI SQL isolation levels. In: ACM SIGMOD INTERNATIONAL CONFERENCE ON MANAGEMENT OF DATA, 1995, San Jose. **Proceedings** [...]. New York: ACM, 1995. p. 1-10. DOI: 10.1145/223784.223785.

BOOKSY. **Agende serviços de beleza em poucos cliques**. [S. l.], [2026]. Disponível em: https://booksy.com/pt-br/. Acesso em: 3 set. 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). **Diário Oficial da União**: seção 1, Brasília, DF, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 20 out. 2026.

CAMÊLO, Moisés Neves; ALVES, Carina. G-Priv: um guia para apoiar a especificação de requisitos de privacidade em conformidade com a LGPD. **iSys: Revista Brasileira de Sistemas de Informação**, Porto Alegre, v. 16, n. 1, 2023. DOI: 10.5753/isys.2023.2743.

CGI.br. **Pesquisa sobre o uso das tecnologias de informação e comunicação nas empresas brasileiras**: TIC Empresas 2023. São Paulo, 2023. Disponível em: https://cetic.br/pt/pesquisa/empresas/. Acesso em: 11 ago. 2026.

EVANS, David S.; SCHMALENSEE, Richard. **Matchmakers**: the new economics of multisided platforms. Boston: Harvard Business Review Press, 2016.

GEFEN, David; KARAHANNA, Elena; STRAUB, Detmar W. Trust and TAM in online shopping: an integrated model. **MIS Quarterly**, Minneapolis, v. 27, n. 1, p. 51-90, 2003. DOI: 10.2307/30036519.

GIL, Antonio Carlos. **Como elaborar projetos de pesquisa**. 6. ed. São Paulo: Atlas, 2017.

GUIMARÃES, Ítalo José Bastos. **Acessibilidade em websites de comércio eletrônico**: avaliação através da interação com usuários cegos. 2016. 172 f. Dissertação (Mestrado em Ciência da Informação) – Universidade Federal da Paraíba, João Pessoa, 2016. Disponível em: https://repositorio.ufpb.br/jspui/handle/tede/8312. Acesso em: 18 ago. 2026.

HILTON, Michael *et al.* Usage, costs, and benefits of continuous integration in open-source projects. In: IEEE/ACM INTERNATIONAL CONFERENCE ON AUTOMATED SOFTWARE ENGINEERING, 31., 2016, Singapura. **Proceedings** [...]. New York: ACM, 2016. p. 426-437. DOI: 10.1145/2970276.2970358.

KLEPPMANN, Martin. **Designing data-intensive applications**: the big ideas behind reliable, scalable, and maintainable systems. Sebastopol: O'Reilly Media, 2017.

KRAWCZYK, Hugo; BELLARE, Mihir; CANETTI, Ran. **HMAC**: keyed-hashing for message authentication. [S. l.]: IETF, 1997. (RFC 2104). Disponível em: https://datatracker.ietf.org/doc/html/rfc2104. Acesso em: 22 set. 2026.

LAUDON, Kenneth C.; LAUDON, Jane Price. **Management information systems**: managing the digital firm. 13. ed. Boston: Pearson, 2014.

LAUDON, Kenneth C.; TRAVER, Carol Guercio. **E-commerce**: business, technology, society. 16. ed. Boston: Pearson, 2021.

LEE, Jin Woo; LEE, Soo Hee. User participation and valuation in digital art platforms: the case of Saatchi Art. **European Journal of Marketing**, [s. l.], v. 53, n. 6, p. 1125-1151, 2019. DOI: 10.1108/EJM-12-2016-0788.

MERCADO PAGO. **Documentação para desenvolvedores**: Checkout Pro e webhooks. São Paulo: Mercado Livre, 2024. Disponível em: https://www.mercadopago.com.br/developers/pt/docs. Acesso em: 8 set. 2026.

NAGAPPAN, Nachiappan *et al.* Realizing quality improvement through test driven development: results and experiences of four industrial teams. **Empirical Software Engineering**, [s. l.], v. 13, n. 3, p. 289-302, 2008. DOI: 10.1007/s10664-008-9062-z.

NEWMAN, Sam. **Building microservices**: designing fine-grained systems. Sebastopol: O'Reilly Media, 2015.

NIELSEN, Jakob. **Usability engineering**. San Francisco: Morgan Kaufmann, 1994.

NIELSEN, Jakob; MOLICH, Rolf. Heuristic evaluation of user interfaces. In: CONFERENCE ON HUMAN FACTORS IN COMPUTING SYSTEMS, 1990, Seattle. **Proceedings** [...]. New York: ACM, 1990. p. 249-256. DOI: 10.1145/97243.97281.

NODE.JS. **Node.js v24.x LTS documentation**. [S. l.]: OpenJS Foundation, 2026. Disponível em: https://nodejs.org/docs/. Acesso em: 14 set. 2026.

OWASP. **OWASP Top 10**: the ten most critical web application security risks. [S. l.], 2021. Disponível em: https://owasp.org/Top10/. Acesso em: 25 ago. 2026.

PCI SECURITY STANDARDS COUNCIL. **Payment Card Industry (PCI) Data Security Standard**: requirements and testing procedures, v4.0. Wakefield, 2022.

PERCIVAL, Colin; JOSEFSSON, Simon. **The scrypt password-based key derivation function**. [S. l.]: IETF, 2016. (RFC 7914). Disponível em: https://www.rfc-editor.org/rfc/rfc7914. Acesso em: 29 set. 2026.

POSTGRESQL GLOBAL DEVELOPMENT GROUP. **PostgreSQL 17 documentation**. [S. l.], 2026. Disponível em: https://www.postgresql.org/docs/17/. Acesso em: 1 set. 2026.

PRESSMAN, Roger S.; MAXIM, Bruce R. **Engenharia de software**: uma abordagem profissional. 9. ed. Porto Alegre: AMGH, 2021.

PRODANOV, Cleber Cristiano; FREITAS, Ernani Cesar de. **Metodologia do trabalho científico**: métodos e técnicas da pesquisa e do trabalho acadêmico. 2. ed. Novo Hamburgo: Feevale, 2013.

REACT. **React**: a JavaScript library for building user interfaces. [S. l.]: Meta Open Source, 2024. Disponível em: https://react.dev/. Acesso em: 19 ago. 2026.

RICHARDS, Mark; FORD, Neal. **Fundamentals of software architecture**: an engineering approach. Sebastopol: O'Reilly Media, 2020.

RICUCCI, Rachel; BLANK, Grant. The limits of platforms: why disintermediation has failed in the art market. **New Media & Society**, [s. l.], v. 28, n. 5, p. 1936-1954, 2026. DOI: 10.1177/14614448251316498.

SCHWABER, Ken; SUTHERLAND, Jeff. **The Scrum guide**: the definitive guide to Scrum: the rules of the game. [S. l.]: Scrum.org, 2020. Disponível em: https://scrumguides.org/. Acesso em: 6 ago. 2026.

SHOPIFY. **Shopify Help Center**: inventory and locations. [S. l.], [2026]. Disponível em: https://help.shopify.com/en/manual/inventory-and-locations. Acesso em: 26 ago. 2026.

SILBERSCHATZ, Abraham; KORTH, Henry F.; SUDARSHAN, S. **Database system concepts**. 7. ed. New York: McGraw-Hill Education, 2020.

SOMMERVILLE, Ian. **Engenharia de software**. 10. ed. São Paulo: Pearson, 2019.

SOUSA, Henrique Adriano de; KLEIN, Luciana; VOESE, Simone Bernardes. O impacto das pressões institucionais na adoção e manutenção do e-commerce em micro e pequenas empresas (MPEs) brasileiras. **Revista Brasileira de Gestão de Negócios**, São Paulo, v. 24, n. 2, p. 366-382, 2022. DOI: 10.7819/rbgn.v24i2.4174.

STEFANOV, Stoyan. **React**: up & running: building web applications. Sebastopol: O'Reilly Media, 2016.

TANENBAUM, Andrew S.; WETHERALL, David J. **Redes de computadores**. 5. ed. São Paulo: Pearson Prentice Hall, 2011.

TATTOODO. **Find & book tattoo artists near you**. [S. l.], [2026]. Disponível em: https://www.tattoodo.com/. Acesso em: 3 set. 2026.

TURBAN, Efraim *et al.* **Electronic commerce**: a managerial and social networks perspective. 8. ed. Cham: Springer, 2015.

VERCEL. **Next.js 16 documentation**: App Router and Server Actions. [S. l.], 2026. Disponível em: https://nextjs.org/docs. Acesso em: 16 set. 2026.

VIGO, Markel; BROWN, Justin; CONWAY, Vivienne. Benchmarking web accessibility evaluation tools: measuring the harm of sole reliance on automated tests. In: INTERNATIONAL CROSS-DISCIPLINARY CONFERENCE ON WEB ACCESSIBILITY, 10., 2013, Rio de Janeiro. **Proceedings** [...]. New York: ACM, 2013. p. 1-10. DOI: 10.1145/2461121.2461124.

W3C. **Web Content Accessibility Guidelines (WCAG) 2.1**. [S. l.], 2018. Disponível em: https://www.w3.org/TR/WCAG21/. Acesso em: 6 out. 2026.

WEICHSELBAUM, Lukas *et al.* CSP is dead, long live CSP! On the insecurity of whitelists and the future of content security policy. In: ACM SIGSAC CONFERENCE ON COMPUTER AND COMMUNICATIONS SECURITY, 2016, Viena. **Proceedings** [...]. New York: ACM, 2016. p. 1376-1387. DOI: 10.1145/2976749.2978363.